

Attack Surface Management

THE BOIM ASM

사용자 메뉴얼

CONTENTS

목차

01. 시작하기

로그인, 화면 구성, 역할과 권한

02. 대시보드

통계, 위협 분포, 트렌드, 인사이트

03. 자산 관리

등록, 디스커버리, 태그, 일괄 작업

04. 스캔 관리

프로파일, 실행, 진행률, 예약

05. 위협 관리

목록, 상태 관리, 일괄 처리

06. 서비스 관리

포트, SSL/TLS, 보안 헤더

07. Shadow IT

탐지, 검토, 자산 변환, 화이트리스트

08. 보고서

유형, 생성, 예약, Compliance

09. 인텔리전스

RSS 피드, 키워드, 알림

10. 감사로그

활동 기록, 필터링

11. 설정

API 키, 브랜딩, LLM, 사용자

12. 실험실

Tor, 엔드포인트, CVE 룰, AI

13. 웹 매뉴얼

웹 매뉴얼 상세 가이드

A decorative curved line on the left side of the slide, with three dots. The top and bottom dots are dark teal, and the middle dot is white. The number '00' is to the right of the top dot.

00

01. 시작하기

로그인, 화면 구성, 역할과 권한

02

01. 시작하기 - 로그인

강력한 인증 보안 및 데이터 격리 아키텍처

멀티테넌시 기반 데이터 격리

- 모든 데이터는 테넌트(Tenant) 단위로 독립적으로 격리하여 관리함
- 조직별 보안 정보를 안전하게 보호하여 데이터 간섭을 원천 차단함



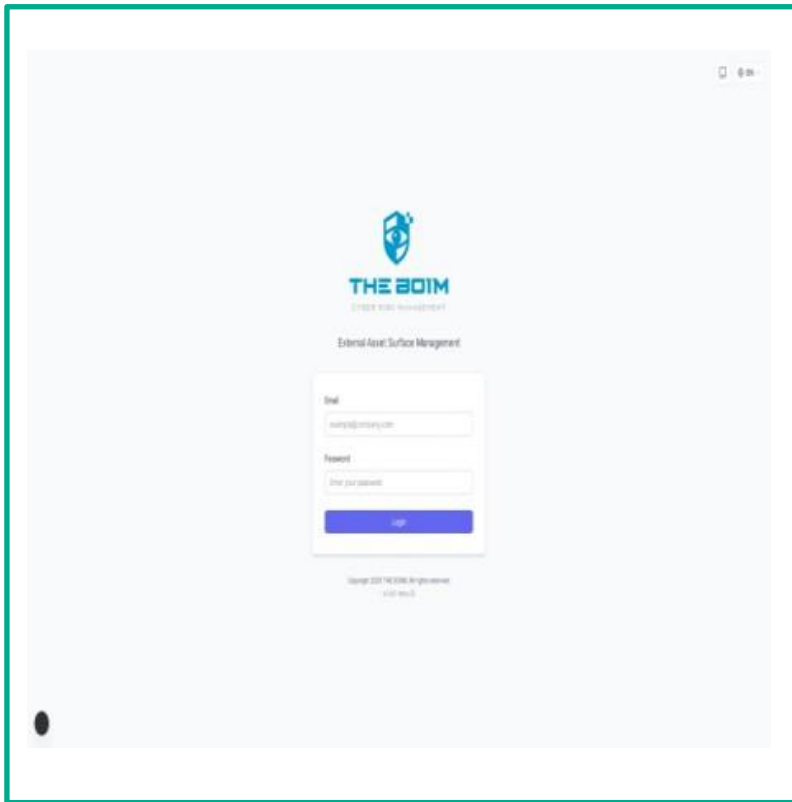
계정 보호를 위한 자동 잠금 정책

- 로그인 5회 연속 오류 발생 시, 해당 계정을 5분간 자동 잠금 처리함
- 무차별 대입 공격(Brute-force) 등 비정상적인 접근 시도로부터 계정 탈취를 방지함

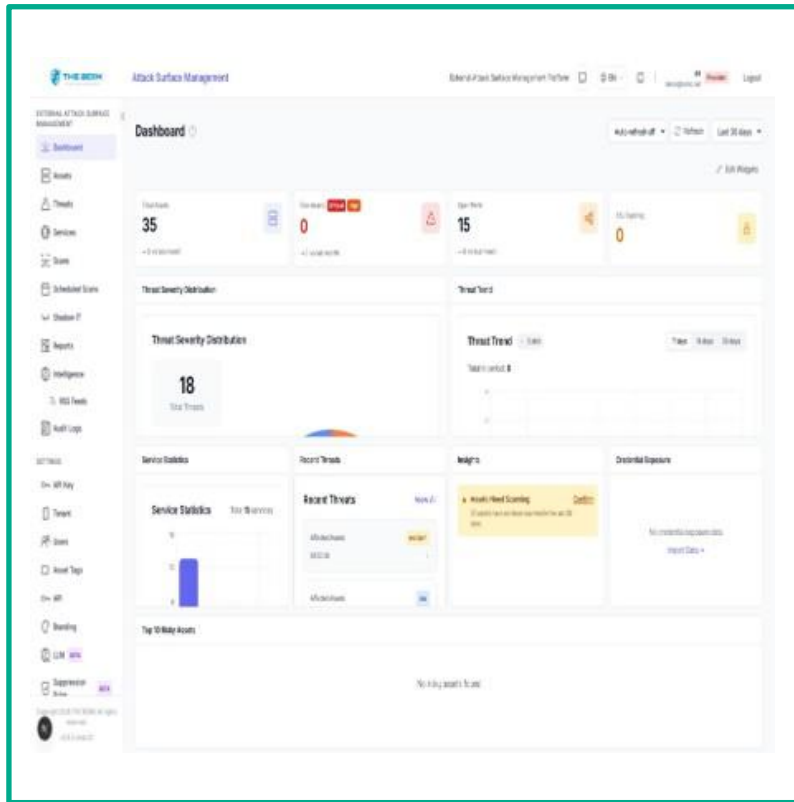


투명한 접속 이력 및 감사 로그

- 모든 로그인 시도와 인증 이벤트는 접속 IP 주소와 함께 상세히 기록함
- 감사 로그를 통해 모든 접근 이력을 철저히 추적하고 모니터링함



01. 시작하기 - 화면구성



직관적인 사용자 경험을 위한 통합 인터페이스 구성

3단 영역 기반의 표준 레이아웃

- 플랫폼 화면을 왼쪽 사이드바, 상단 헤더, 중앙 콘텐츠 등 3개 영역으로 일관되게 구성함
- 모든 페이지에 동일한 레이아웃을 유지하여 사용자에게 직관적인 인터페이스를 제공함



효율적인 작업 공간 및 유틸리티

- 사이드바 내 접기/펼치기 토글 버튼을 통해 필요에 따라 넓은 작업 공간을 확보할 수 있음
- 상단 헤더에 언어 선택, 다크모드 전환, 프로필 접근 등 핵심 유틸리티 기능을 통합 배치함



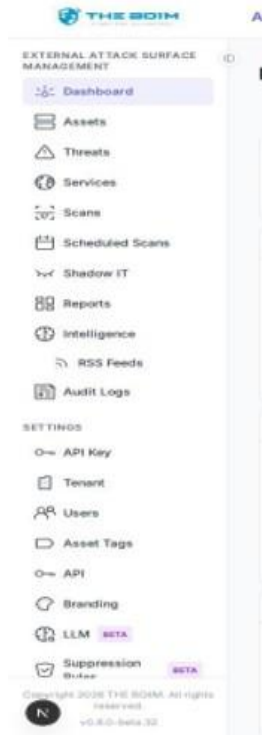
실시간 데이터 시각화 및 대시보드

- 중앙 콘텐츠 영역을 통해 선택한 메뉴의 상세 정보와 보안 위협 현황을 실시간으로 표시함
- 자산 정보, 위협 분포, 최근 탐지 내역 등을 한눈에 파악할 수 있도록 시각화하여 제공함



01. 시작하기 - 화면구성(사이드바 메뉴)

역할 및 목적별 3개 섹션 중심의 사이드바 구성



외부 자산 관리 (External Asset Management)



- 대시보드, 자산, 위협, 스캔, Shadow IT 등 플랫폼의 핵심 기능을 수행하는 11개 주요 메뉴를 배치함
- 외부 공격 표면 관리(EASM)를 위한 통합적인 가시성과 제어 기능을 제공함

실험실 (LAB) 및 베타 기능



- 엔드포인트 디스커버리, CVE 를 생성기 등 새롭게 추가된 6개의 베타 기능을 별도로 구성함
- 테넌트 설정에 따라 활성화되며, 최신 보안 기술을 선제적으로 경험할 수 있는 플레이그라운드를 제공함

설정 (Settings) 및 권한 관리



- API 키 관리, 사용자 관리, 브랜딩 등 시스템 운영에 필수적인 9개 관리 항목을 통합함
- 사용자 역할(Role)에 따른 메뉴 접근 권한을 차등 부여하여 플랫폼 운영의 보안성을 강화함

01. 시작하기 - 역할과 권한

5단계 역할 기반 접근 제어(RBAC)를 통한 권한 최적화



관리자 그룹 (Owner / Admin)

- Owner: 테넌트 소유자로서 시스템 전반에 대한 무제한 제어 권한을 보유함
 - Admin: 사용자 관리, 브랜딩 설정 등 조직 수준의 시스템 구성을 담당함
-



운영 및 분석 그룹 (Editor / Analyst)

- Editor: 자산 등록, 삭제 및 스캔 실행 등 실무 운영 권한을 수행함
 - Analyst: 데이터 조회 및 보안 보고서 생성 권한을 통해 효율적인 위협 분석 업무를 지원함
-



모니터링 그룹 (Viewer)

- Viewer: 보안 현황 확인을 위한 읽기 전용(Read-only) 접근 권한만 부여함
- 데이터 수정 및 설정 변경 권한을 엄격히 제한하여 플랫폼 운영의 보안성을 유지함

01. 시작하기 - 기본 용어

정밀한 위협 평가를 위한 자산 및 위험 지수 관리



자산(Asset) 및 위협(Threat)

- 자산: 스캔 대상이 되는 조직의 모든 IT 인프라 리소스를 의미함
 - 위협: 자산에서 탐지된 소프트웨어 취약점(CVE), 설정 오류 등 잠재적 보안 리스크를 정의함
-



기술/예측 지표 (CVSS / EPSS)

- CVSS: 취약점이 가진 기술적 심각도를 점수화하여 표준화된 위험 수치를 제공함
 - EPSS: 해당 취약점이 실제 공격에 악용될 확률을 수치화하여 실질적인 조치 우선순위 결정을 지원함
-



미등록 자산 및 중요도 (Shadow IT / Tier)

- Shadow IT: 보안 관리자의 통제를 벗어난 비인가 자산을 식별하여 공격 표면 사각지대를 제거함
- Tier 관리: 자산의 비즈니스 중요도에 따라 3단계 등급으로 분류하여 핵심 자산에 대한 집중 관리 체계를 구축함



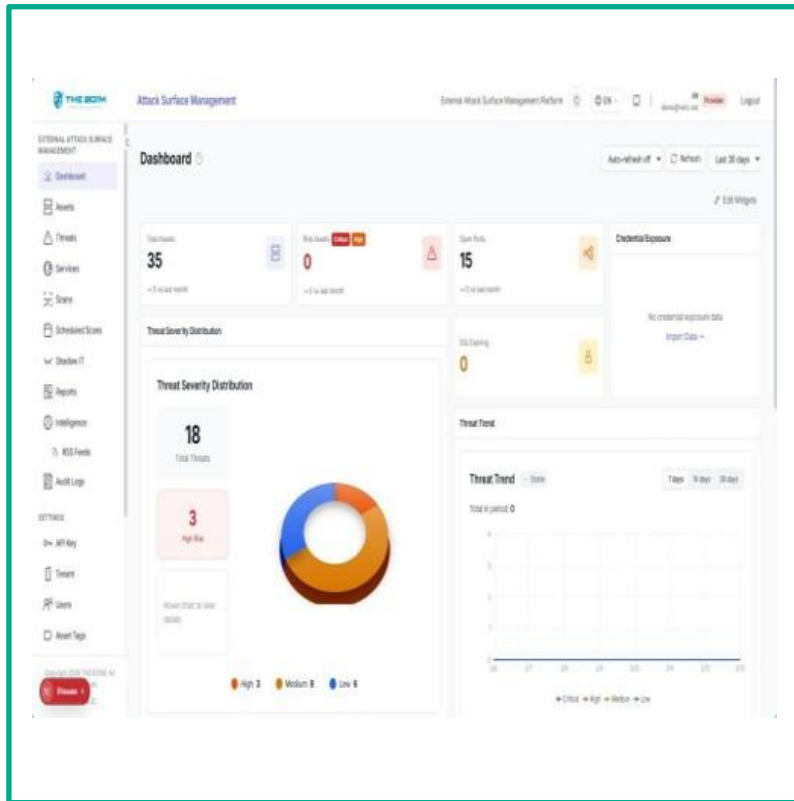
00

02. 대시보드

통계, 위험 분포, 트렌드, 인사이트

02

02. 대시보드 - 대시보드 개요



실시간 보안 현황 가시성 확보를 위한 통합 대시보드

종합 보안 지표 요약



- 통계 카드, 위험 분포 차트, 트렌드 그래프를 통해 조직의 전체 보안 상태를 한 화면에 요약하여 제공함
- 자산 현황과 주요 위험 지표를 시각화하여 보안 관리자의 즉각적인 상황 판단을 지원함

데이터 조회 최적화 및 속도



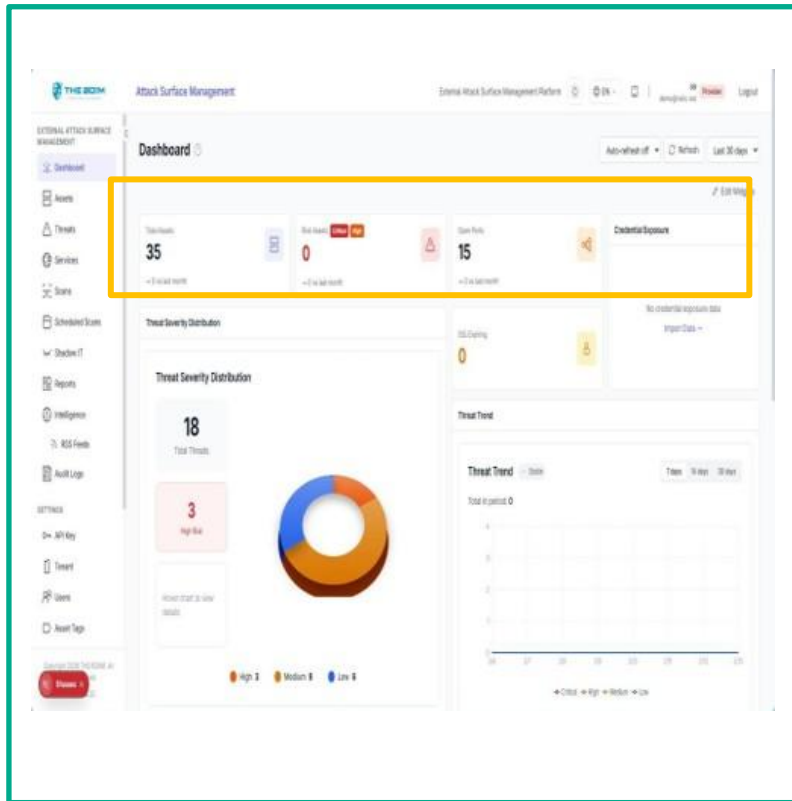
- Redis 캐싱 기술을 적용하여 30~300초 TTL 기반의 고성능 데이터 조회를 지원함
- 대량의 보안 데이터를 지연 없이 실시간으로 처리하여 분석 효율성을 극대화함

사용자 맞춤형 모니터링



- 30초, 1분, 5분 등 유연한 자동 새로고침 옵션을 지원하여 운영 패턴에 최적화된 실시간 관제 환경을 제공함
- 관리자의 필요에 따라 대시보드 위젯 구성을 최적화하여 맞춤형 보안 모니터링이 가능함

02. 대시보드 - 통계 카드



핵심 보안 지표 가시화를 위한 4대 통계 카드 구성

자산 및 위협 관리 현황



- 등록된 전체 자산 개수와 신규 증가분을 표시하며, 클릭 시 자산 관리 페이지로 즉시 이동함
- 위험 자산 수를 Critical 및 High 등급별로 시각화하여 위험 우선순위에 따른 신속한 대응을 지원함

서비스 및 인증서 보안 모니터링



- 스캔을 통해 발견된 활성화 서비스 포트의 총합계를 실시간으로 산출하여 표시함
- 30일 이내 만료가 임박한 HTTPS 서비스 인증서 개수를 경고하여 중단 없는 서비스 운영을 보장함

직관적인 데이터 시각화



- 지표의 전월 대비 증가량은 빨간색, 감소량은 녹색으로 구분 표기하여 보안 상태의 변화를 직관적으로 파악할 수 있음
- 정량적인 수치와 증감률을 동시에 제공하여 인프라 확장 및 위험 감소 추이를 효과적으로 관리함

02. 대시보드 - 위협 분포

심각도별 위협 분포 파이 차트 및 실시간 분석

4단계 위협 심각도 분류

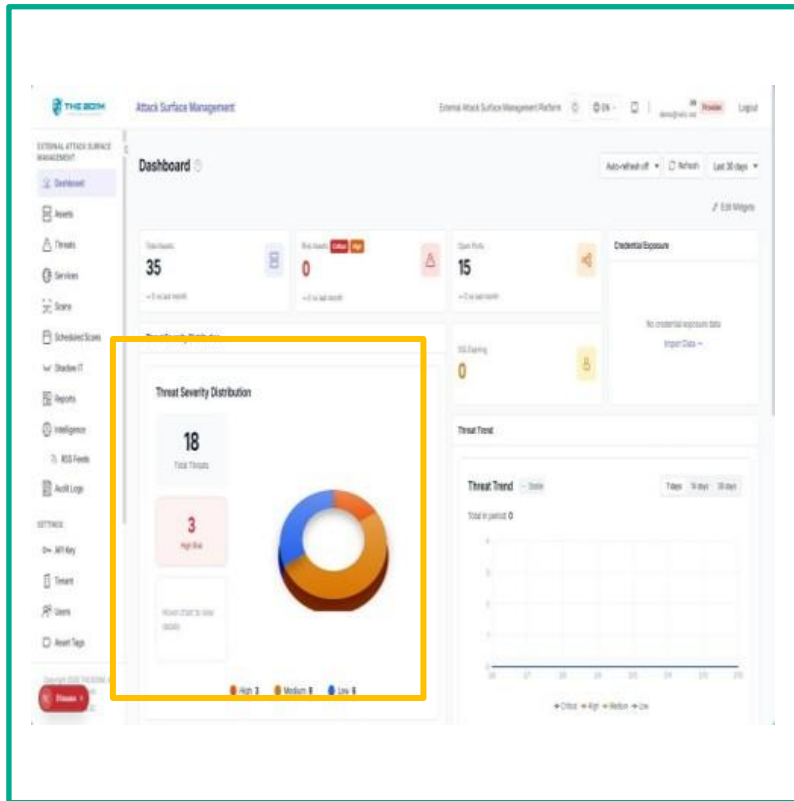
- 현재 위협을 Critical(빨강), High(주황), Medium(노랑), Low(파랑) 등 4개 등급으로 구분하여 시각화함.
- 톨팁 호버 시 각 등급별 정확한 위협 개수와 비율을 실시간으로 확인할 수 있음.

데이터 연동 및 필터링 기능

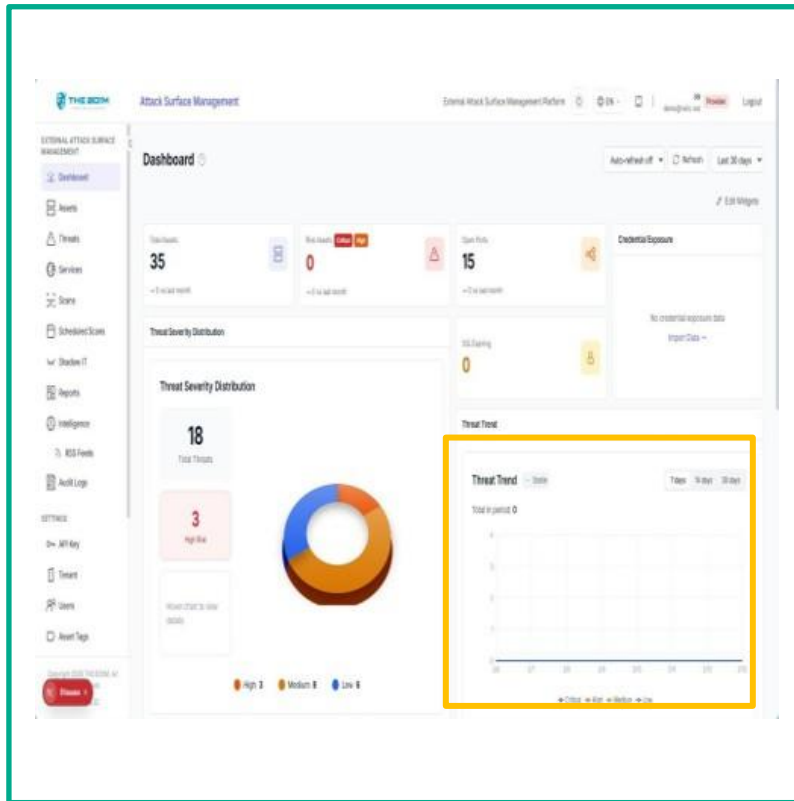
- 파이 차트의 각 색상을 클릭하면 해당 심각도로 필터링된 위협 목록 페이지로 즉시 이동함.
- 위협이 없는 경우 "No data" 메시지를 표시하여 빈 차트 상태를 명확히 전달함.

고속 조회 및 캐싱 기술

- Redis에 2분간 데이터가 캐시되어 다수의 사용자가 접속해도 지연 없는 빠른 조회를 지원함.



02. 대시보드 - 위협 트렌드



심각도별 위협 발생 추이 및 트렌드 자동 판정

기간별 위협 발생 추이 시각화



- 7일, 30일, 90일 중 선택한 기간 동안의 심각도별 위협 발생 현황을 라인 차트로 표시함.
- Critical(빨강), High(주황), Medium(노랑), Low(파랑) 4개 라인이 동시에 표시되어 직관적인 비교가 가능함.

데이터 기반 트렌드 요약 및 판정



- 전반부와 후반부 데이터를 비교하여 10% 이상 변동 시 증가/감소/안정 상태를 자동으로 판정함.
- 전체 위협 수와 함께 트렌드 요약(Increasing/Decreasing/Stable) 정보를 하단에 제공함.

성능 최적화 및 고속 조회



- 일별 심각도별 그룹화 쿼리를 통해 데이터를 수집하며, Redis에 5분간 캐시되어 성능을 최적화함.

02. 대시보드 - 인사이트

보안 현황 자동 분석 및 맞춤형 권장 조치 제공

6가지 유형의 지능형 인사이트 분석

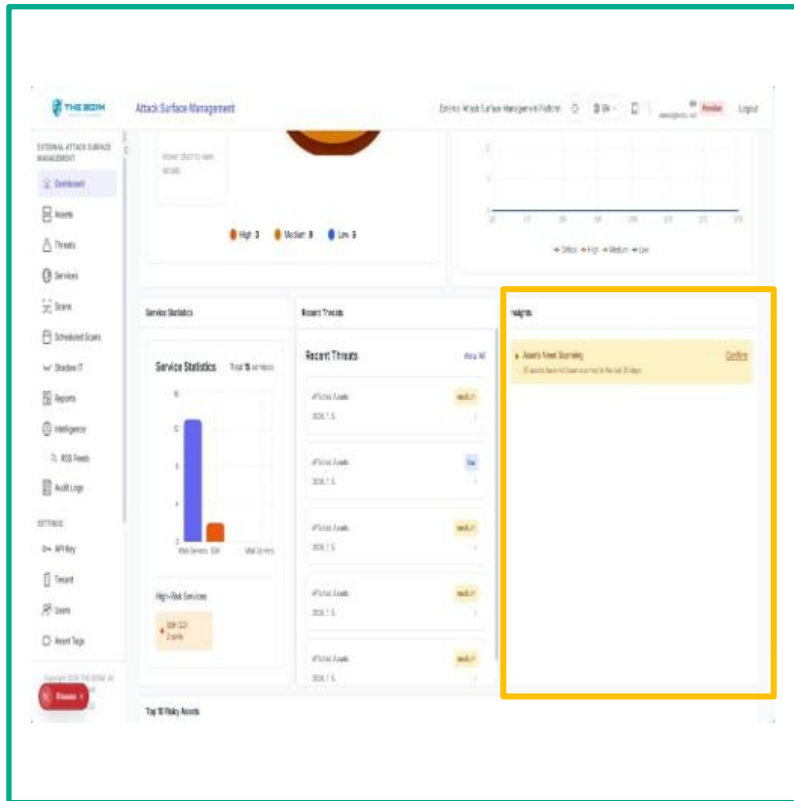
- 시스템이 보안 현황을 자동으로 분석하여 Shadow IT 탐지, 새로운 Critical 위협, SSL 만료 예정 등 총 6가지 유형의 주의 사항을 제공함.
- 각 인사이트는 심각도(Critical, High, Medium, Low)에 따라 분류되어 운영 우선순위 결정을 도움.

직관적인 사용자 액션 및 페이지 연동

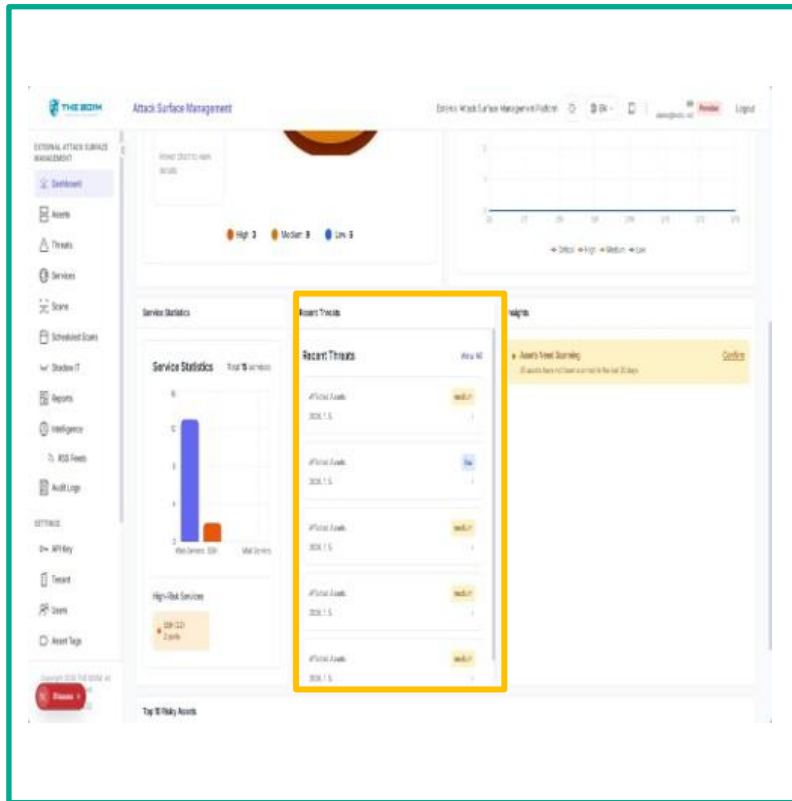
- 인사이트 내 '확인(Confirm)' 버튼 클릭 시 관련 상세 데이터를 확인할 수 있는 해당 페이지로 즉시 이동함.
- 불필요한 알림은 'X' 버튼을 통해 오늘 하루 숨기기(Dismiss) 처리가 가능하여 대시보드 청결도를 유지함.

실시간 보안 상태 요약

- '시스템 정상(Low)' 메시지를 포함하여 현재 조직이 직면한 핵심 보안 이슈를 한눈에 파악할 수 있는 요약 정보를 제공함.



02. 대시보드 - TOP 위험 자산



위험도 기준 상위 10개 자산의 집중 관리 및 상세 분석

위험 자산 TOP 10 실시간 리스트



- 조직 내 위험도가 가장 높은 상위 10개의 자산을 추출하여 테이블 형식으로 제공함.
- 자산명, 유형, 위험도, 위협 수, 최근 스캔 일시 등 5개 핵심 컬럼을 통해 현황을 파악함.

데이터 정렬 및 심층 분석 연동



- 모든 자산은 위험도 내림차순으로 자동 정렬되어 즉각적인 대응 우선순위를 제시함.
- 자산명을 클릭하면 상세 페이지로 이동하여 연결된 위협 목록, 서비스/포트, 스캔 이력을 통합 확인함.

직관적인 위험 지표 시각화



- 각 자산별로 탐지된 위협의 총수와 마지막 스캔 시점을 함께 표시하여 관리의 연속성을 보장함.

A decorative curved line on the left side of the slide, with three dots. The top and bottom dots are dark teal, and the middle dot is white. The numbers 02, 03, and 04 are positioned next to these dots respectively.

02

03. 자산관리

등록, 디스커버리, 태그, 일괄 작업

04

03. 자산관리 - 자산 목록

[illegible]

전체 IT 인프라 자산의 통합 가시성 및 정밀 필터링 제공

7개 핵심 컬럼 기반 자산 테이블



- 등록된 모든 자산을 자산명, 유형, IP 주소, Tier, 위험도, 최근 스캔, 태그 등 7개 항목으로 상세히 표시함.
- 위험도는 연결된 위협 중 가장 높은 심각도를 기준으로 자동 계산되며, 위협 상태 변경 시 즉각 반영됨.

다중 필터 및 검색을 통한 최적화 조회



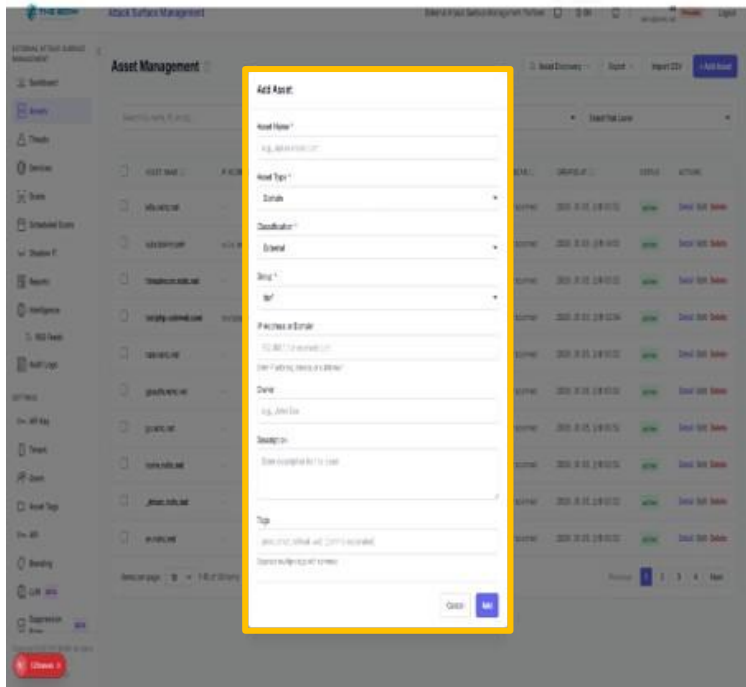
- 타입, 위험도, 태그, Tier 등 다양한 필터 조건과 검색 기능을 통해 원하는 자산을 빠르게 식별할 수 있음.
- 도메인, IP, 서브도메인 등 조직의 모든 자산을 단일 화면에서 효율적으로 통합 관리함.

페이지 간 선택 상태 유지 (Selection Persistence)



- 자산 선택 후 상세 페이지로 이동했다가 복귀하더라도 기존의 선택 상태가 그대로 유지되어 작업 연속성을 보장함.

03. 자산관리 - 수동 등록



정확한 자산 식별을 위한 다각적 속성 정의 및 중복 검증

5단계 자산 속성 정의



- 자산 추가 시 타입(Domain/IP 등), 자산명, Tier, 태그, 설명 등 5가지 핵심 정보를 입력하여 체계적으로 등록함.
- 태그는 설정 메뉴에서 사전 정의된 목록을 선택하여 관리의 통일성을 유지할 수 있음.

테넌트 기반 데이터 중복 체크



- 입력된 자산명과 IP 주소는 해당 테넌트 내에서 실시간으로 중복 여부를 검증함.
- 이미 존재하는 자산일 경우 오류 메시지와 함께 기존 정보가 표시되어 데이터 무결성을 보장함.

중요도 기반 Tier 분류 (1/2/3)



- 자산의 비즈니스 중요도에 따라 **Tier 1(핵심), Tier 2(중요), Tier 3(일반)**으로 구분하여 관리 우선순위를 설정함.

03. 자산관리 - csv 가져오기

CSV 템플릿 기반의 대량 자산 일괄 등록 및 데이터 정제

수백~수천 개 자산의 일괄 등록 프로세스

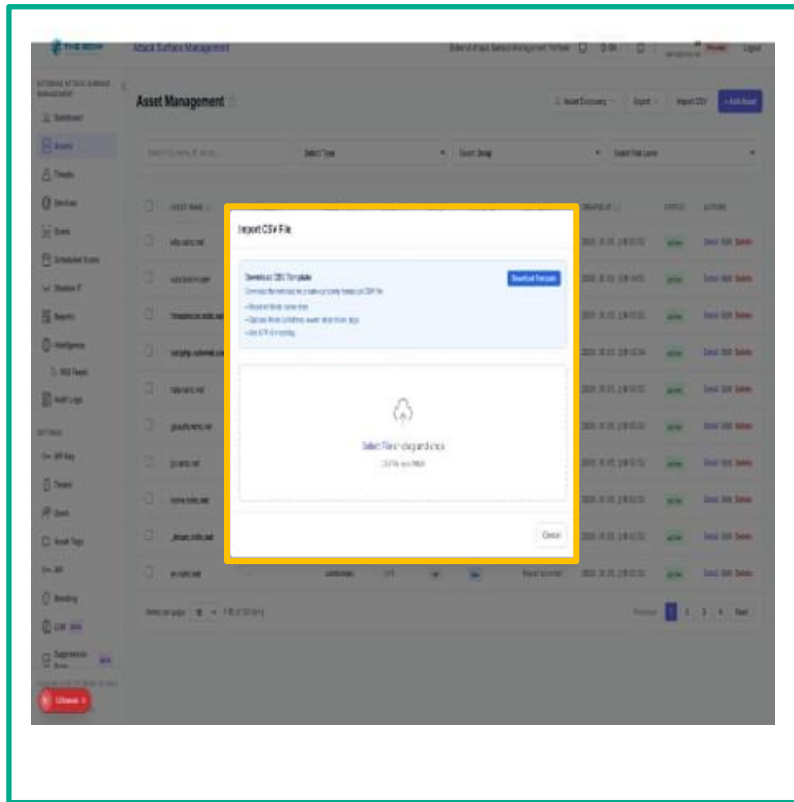
- 제공되는 표준 템플릿을 다운로드하여 자산명, 타입, IP/도메인, Tier 등 7개 필수 및 선택 컬럼을 작성 후 업로드함.
- 파일 업로드 시 초기 5행에 대한 미리보기를 제공하여 데이터의 형식을 사전에 검토할 수 있음.

유연한 데이터 중복 처리 옵션

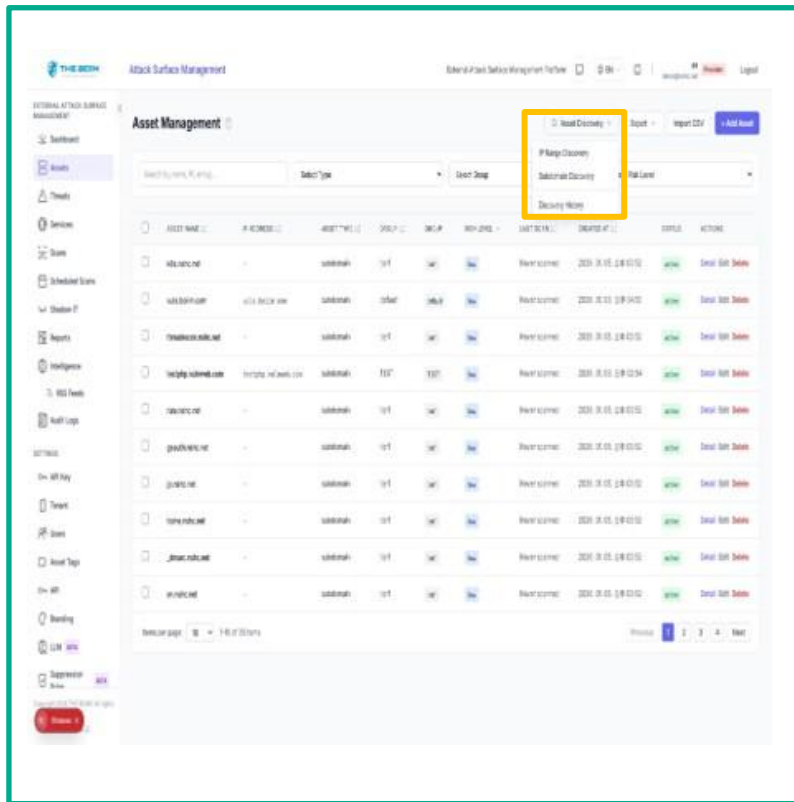
- 건너뛰기, 덮어쓰기, 병합 등 3가지 중복 처리 옵션을 지원하여 기존 데이터와의 충돌을 효율적으로 관리함.
- 자산명 기준의 엄격한 중복 체크가 수행되며, IP 주소 중복의 경우 경고 표시를 통해 관리자의 판단을 도움.

실시간 처리 결과 리포팅

- 가져오기 완료 후 전체 성공, 실패, 건너뛴 건수를 즉시 표시하여 대량 등록 결과에 대한 투명성을 확보함.



03. 자산관리 - 자산 디스커버리



미등록 자산의 자동 발굴을 위한 다각적 스캔 및 탐색 기술

유연한 IP 범위 디스커버리

- 단일 IP는 물론, IP 범위(192.168.1.1-100) 및 CIDR(192.168.1.0/24) 형식을 모두 지원하여 네트워크 내 활성 호스트를 정밀하게 식별함.
- 발견된 호스트는 운영 목적에 따라 공식 자산 또는 Shadow IT로 분류하여 즉시 등록할 수 있음.

다중 소스 기반 서브도메인 탐색

- 5개 이상의 외부 데이터 소스를 병렬로 조회하여 조직의 숨겨진 서브도메인을 포괄적으로 탐색함.
- 와일드카드 탐지 옵션을 통해 불필요한 노이즈를 제거하고 실제 의미 있는 도메인 자산만을 선별함.

실시간 운영 상태(HTTP) 검증

- 탐지된 자산에 대한 HTTP 체크를 병행하여 실제 서비스가 활성화되어 운영 중인지를 실시간으로 확인함.

03. 자산관리 - 태그 관리

조직 맞춤형 태그 시스템을 통한 자산 그룹화 및 정밀 필터링

유연한 자산 분류 및 그룹화

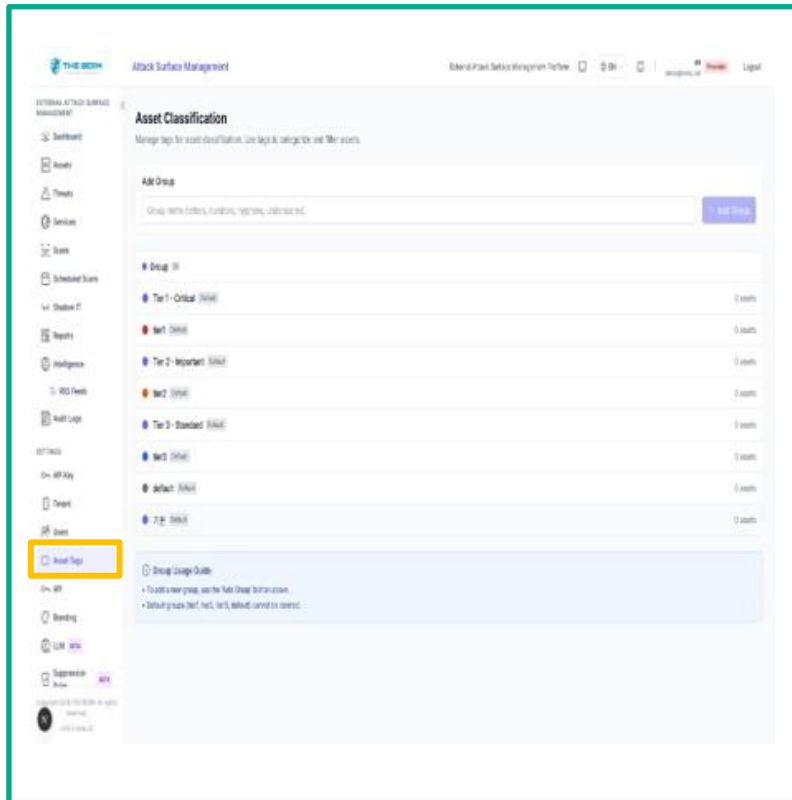
- 자산 수정 modal의 태그 필드를 통해 운영 환경(Production, Dev)이나 용도별 커스텀 태그를 자유롭게 할당할 수 있음.
- 기본 제공되는 Tier(1/2/3) 외에 조직의 분류 기준에 맞춘 태그 시스템을 구축하여 관리 효율성을 높임.

태그 기반 자산 검색 및 필터링

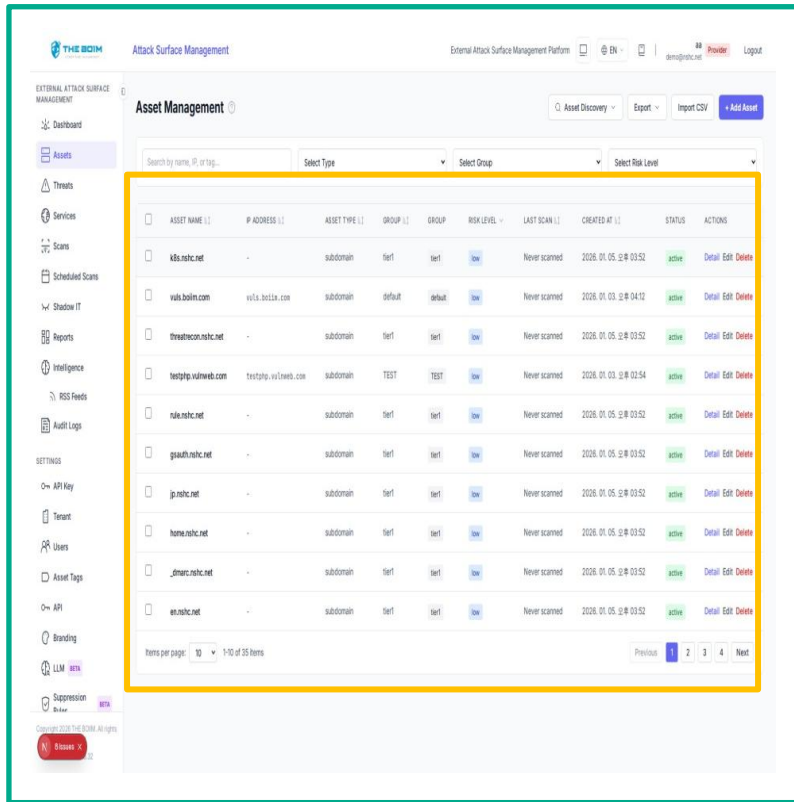
- 검색창에 태그명을 입력하여 해당 태그가 포함된 자산만 빠르게 선별하는 정밀 필터링 기능을 지원함.
- 수많은 자산 중 특정 프로젝트나 관리 그룹에 속한 자산을 즉각적으로 식별할 수 있음.

전용 관리 메뉴를 통한 라이프사이클 관리

- 설정 메뉴의 '자산 분류'에서 새로운 태그 생성, 이름 및 색상 변경, 삭제 등 통합적인 태그 관리를 수행함.
- - 시스템 태그를 제외한 커스텀 태그를 자유롭게 수정하여 자산 관리 정책 변화에 유연하게 대응함.



03. 자산관리 - 자산 상세



4개 핵심 탭 구성을 통한 자산별 위협 및 이력 통합 분석

다각적 자산 정보 및 위협 가시성

- 자산명을 클릭하여 진입하는 상세 페이지에서는 자산명, 유형, IP/도메인, Tier, 태그 등 기본 정보와 함께 담당자 정보를 한눈에 확인함.
- 연결된 위협 목록 탭을 통해 해당 자산에서 발견된 모든 보안 취약점을 심각도별로 분류하여 심층 분석할 수 있음.

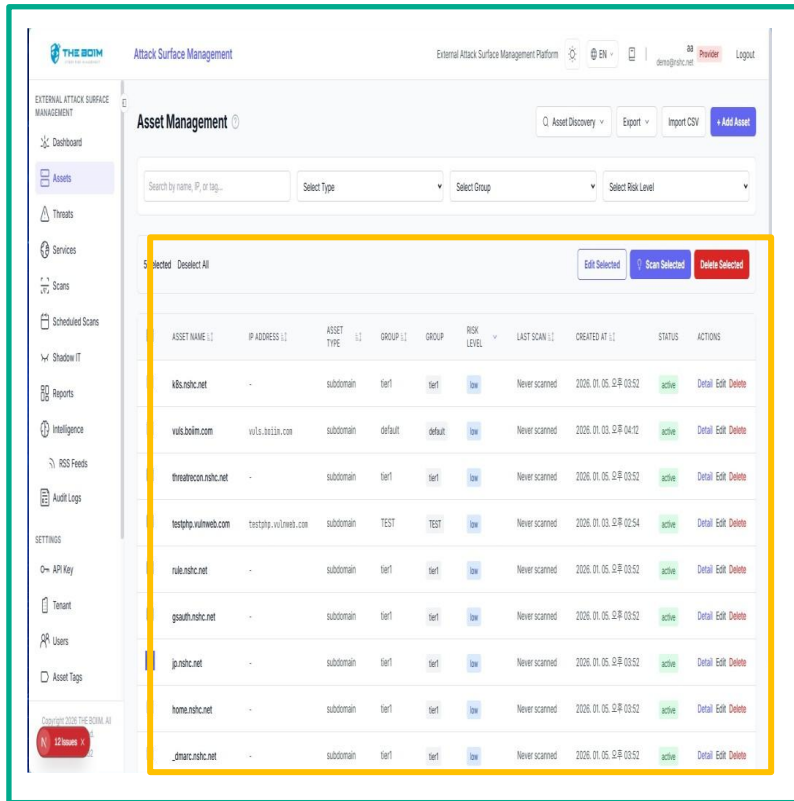
서비스 탐지 및 엔드포인트 분석

- 발견된 서비스/포트 탭에서 해당 자산의 활성화된 네트워크 서비스 상태를 실시간으로 모니터링함.
- Katana 기반의 엔드포인트 탐색 결과를 제공하여 자산 내부에 숨겨진 위협 노출 지점을 정밀하게 파악함.

관리 연속성을 위한 스캔 이력 추적

- 스캔 이력 결과 탭을 통해 과거부터 현재까지 수행된 모든 스캔 기록을 추적하고 보안 상태의 변화 추이를 관리함.

03. 자산관리 - 자산 목록



ASSET NAME	IP ADDRESS	ASSET TYPE	GROUP	RISK LEVEL	LAST SCAN	CREATED AT	STATUS	ACTIONS
kids.nshc.net	-	subdomain	tier1	low	Never scanned	2026. 01. 05. 오후 03:52	active	Detail Edit Delete
vuln.boim.com	vuln.boim.com	subdomain	default	low	Never scanned	2026. 01. 05. 오후 04:12	active	Detail Edit Delete
threatcon.nshc.net	-	subdomain	tier1	low	Never scanned	2026. 01. 05. 오후 03:52	active	Detail Edit Delete
testphp.vulnweb.com	testphp.vulnweb.com	subdomain	TEST	low	Never scanned	2026. 01. 05. 오후 02:54	active	Detail Edit Delete
rule.nshc.net	-	subdomain	tier1	low	Never scanned	2026. 01. 05. 오후 03:52	active	Detail Edit Delete
gsauth.nshc.net	-	subdomain	tier1	low	Never scanned	2026. 01. 05. 오후 03:52	active	Detail Edit Delete
js.nshc.net	-	subdomain	tier1	low	Never scanned	2026. 01. 05. 오후 03:52	active	Detail Edit Delete
home.nshc.net	-	subdomain	tier1	low	Never scanned	2026. 01. 05. 오후 03:52	active	Detail Edit Delete
_dmart.nshc.net	-	subdomain	tier1	low	Never scanned	2026. 01. 05. 오후 03:52	active	Detail Edit Delete

전체 IT 인프라 자산의 통합 가시성 및 정밀 필터링 제공

7개 핵심 컬럼 기반 자산 테이블

- 등록된 모든 자산을 자산명, 유형, IP 주소, Tier, 위험도, 최근 스캔, 태그 등 7개 항목으로 상세히 표시함.
- 위험도는 연결된 위험 중 가장 높은 심각도를 기준으로 자동 계산되며, 위험 상태 변경 시 즉각 반영됨.

다중 필터 및 검색을 통한 최적화 조회

- 타입, 위험도, 태그, Tier 등 다양한 필터 조건과 검색 기능을 통해 원하는 자산을 빠르게 식별할 수 있음.
- 도메인, IP, 서브도메인 등 조직의 모든 자산을 단일 화면에서 효율적으로 통합 관리함.

페이지 간 선택 상태 유지 (Selection Persistence)

- 자산 선택 후 상세 페이지로 이동했다가 복귀하더라도 기존의 선택 상태가 그대로 유지되어 작업 연속성을 보장함.

03. 자산관리 - 자산 삭제

안전한 자산 제거를 위한 연관 데이터 동시 삭제 및 이력 기록

단일 및 일괄 삭제의 이중 관리 체계



- 개별 자산의 상세 페이지나 목록에서의 단일 삭제는 물론, 선택 툴바를 통한 대량 일괄 삭제 방식을 모두 지원함.
- 삭제 시 복구가 불가능하다는 경고 메시지와 확인 대화상자를 통해 관리자의 실수로 인한 데이터 손실을 방지함.

연관 보안 데이터의 자동 정제 및 재계산

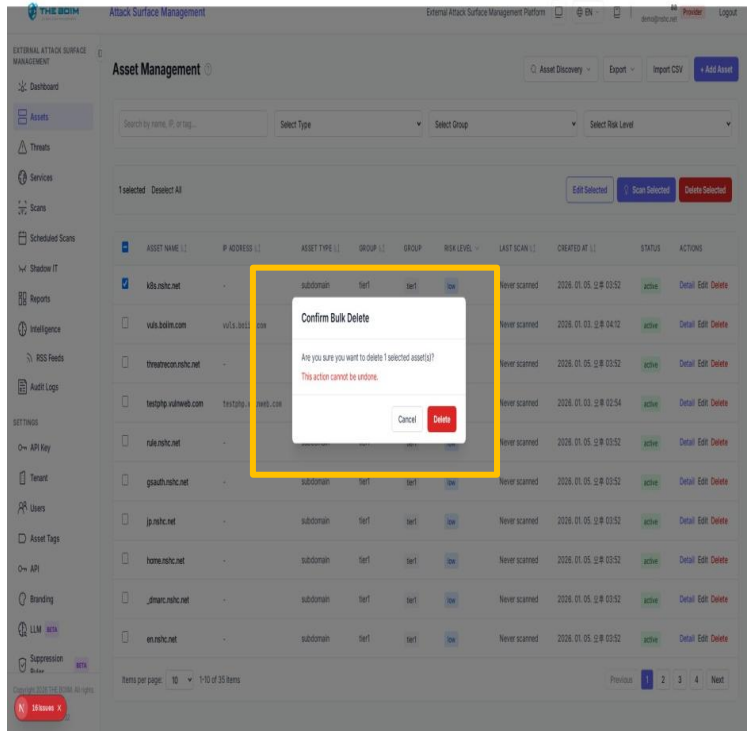


- 자산 삭제 시 해당 자산과 연결된 위협, 서비스, 포트 정보가 실시간으로 동시 제거되어 데이터 무결성을 유지함.
- 영향 받는 위협 목록에서 해당 자산 ID가 자동으로 제외되며, 테넌트 전체의 위험도 점수가 즉시 재계산되어 반영됨.

감사 로그를 통한 삭제 이력 추적



- 자산 삭제를 수행한 사용자 정보, 접속 IP, 수행 일시, 삭제된 자산의 상세 정보가 감사 로그에 자동으로 기록됨.





03

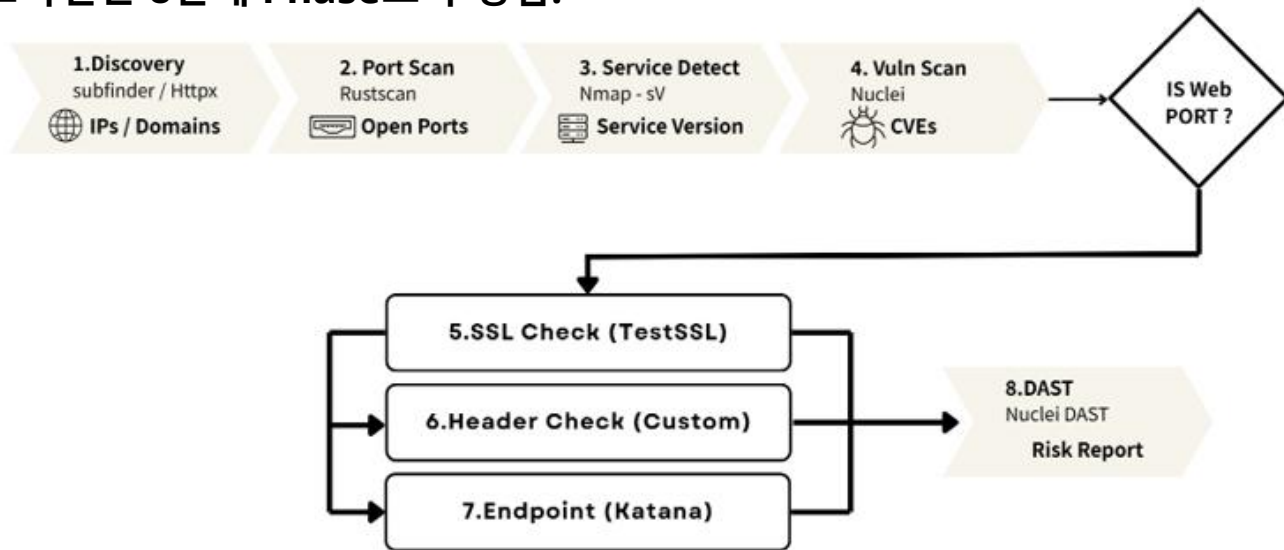
04. 스캔 관리

프로파일, 실행, 진행률, 예약

05

04. 스캔 관리 - 스캔 개요

스캔 파이프라인은 8단계 Phase로 구성됨.



8단계 Phase: Discovery → Port → Service → Vuln → SSL → Header → Endpoint → DAST
Phase 4-6 병렬 실행으로 성능 최적화
전문 도구 자동 실행 (Rustscan, Nmap, Nuclei 등)

04. 스캔 관리 - 스캔 프로파일

진단 목적에 따른 3단계 스캔 프로파일 및 포트 범위 최적화

3가지 전략적 스캔 프로파일 제공

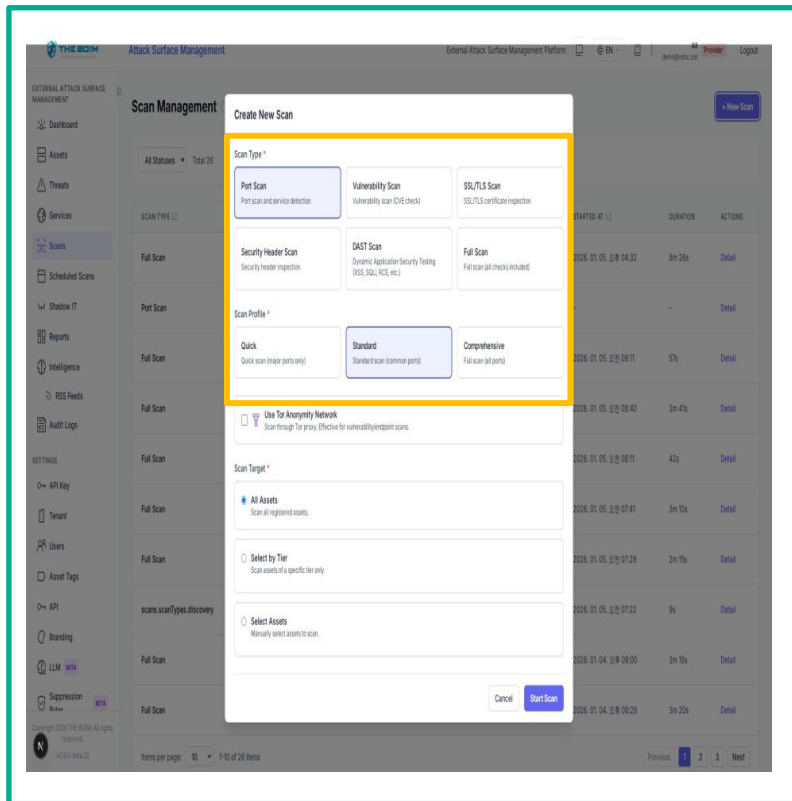
- **Quick:** 포트 및 서비스 탐지만 수행하며, 약 2분 내외의 빠른 점검에 적합함.
- **Standard:** 취약점 및 SSL 인증을 포함하며, 약 10분 내외의 일상적인 스캔에 권장됨.
- **Comprehensive:** 전체 8단계 파이프라인을 약 30분 동안 수행하는 정밀 점검 모드입니다.

프로파일별 차등화된 포트 스캔 범위

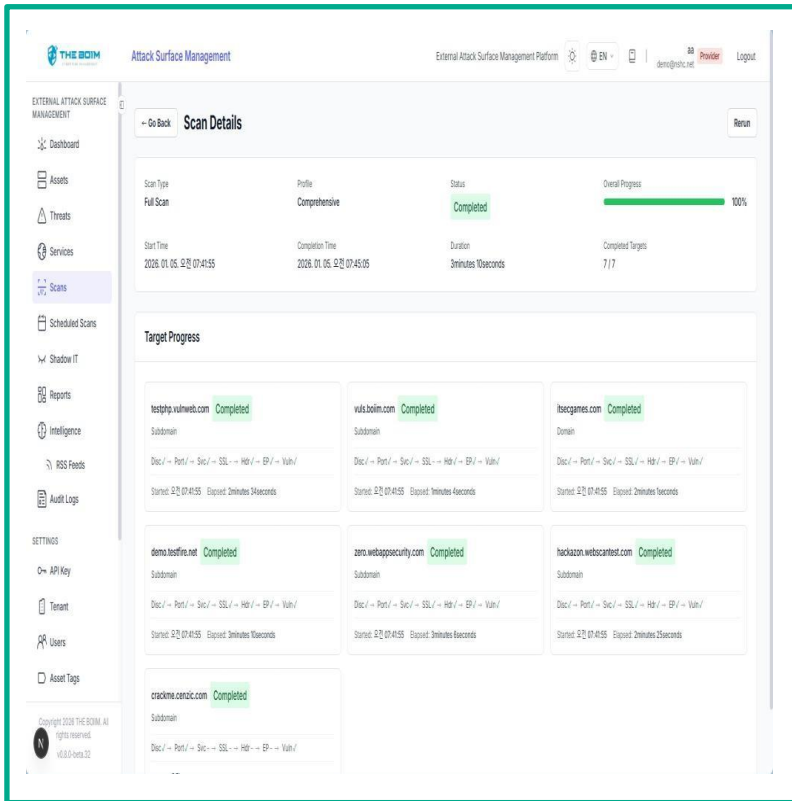
- Quick 프로파일은 상위 100개, Standard는 상위 1,000개 포트를 대상으로 효율적인 스캔을 진행함.
- Comprehensive 프로파일 선택 시 전체 포트를 대상으로 누락 없는 철저한 전수 조사를 수행함.

유연한 스캔 대상 및 옵션 설정

- 전체 자산, 특정 Tier, 혹은 개별 선택 자산 등 운영 환경에 맞춰 스캔 대상을 자유롭게 지정할 수 있음.
- 익명 네트워크(Tor) 사용 옵션을 통해 보안성이 강화된 취약점/엔드포인트 스캔을 지원함.



04. 스캔 관리 - 실시간 진행률



The screenshot displays the 'Attack Surface Management' interface for 'THE BOM'. The main section is titled 'Scan Details' and shows a 'Full Scan' profile that is 'Completed'. A progress bar indicates 100% completion. Below this, a 'Target Progress' section lists several subdomains and their scan status:

Subdomain	Status	Start Time	Completion Time	Duration	Completed Targets
testphp.vulnweb.com	Completed	2028.01.05. 02:07:41:55	2028.01.05. 02:07:41:55	30 minutes 15 seconds	7/7
vuln.bom.com	Completed				
itsecgames.com	Completed				
dema.testfire.net	Completed				
zero.webappsecurity.com	Completed				
hackazon.webocantest.com	Completed				
crackme.careto.com	Completed				

WebSocket 기반의 실시간 상태 업데이트 및 타겟별 상세 모니터링

WebSocket 기반 실시간 데이터 동기화



- 스캔 상세 페이지는 WebSocket을 통해 페이지 새로고침 없이 스캔의 모든 과정을 실시간으로 업데이트함.
- 스캔 시작부터 진행률, 단계 변경, 타겟 상태, 완료 및 오류 등 6가지 핵심 이벤트를 전송받아 즉각적으로 표시함.

직관적인 진행 상태 및 타겟별 모니터링



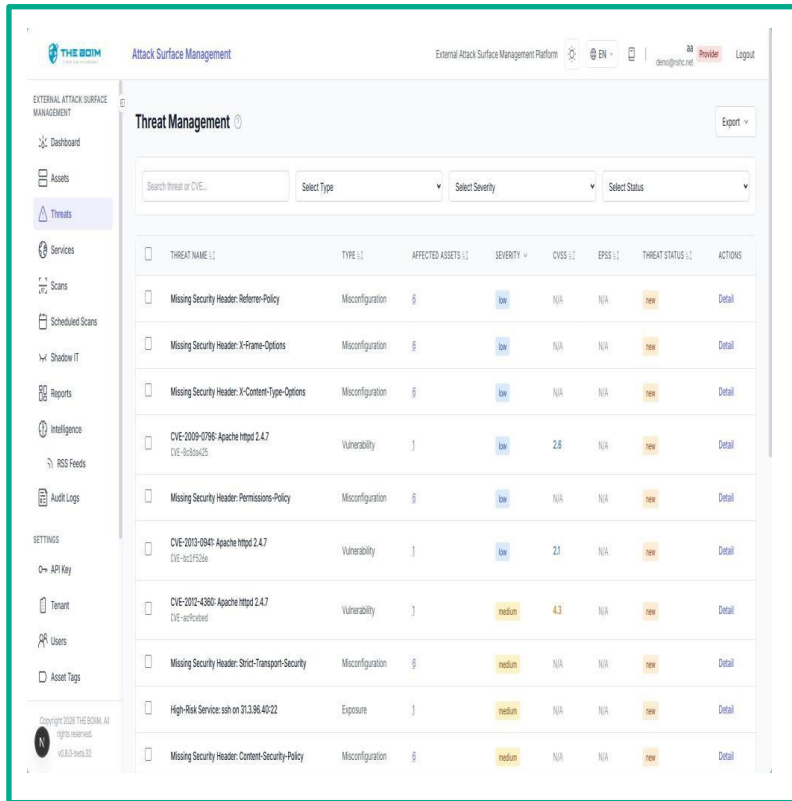
- 전체 타겟 대비 완료 비율을 프로그레스 바(Progress Bar)로 시각화하여 전체적인 진행 상황을 한눈에 파악할 수 있음.
- 개별 타겟별로 현재 수행 중인 단계(Phase)와 시작/종료 시간, 소요 시간 등의 상세 상태를 동시에 추적함.

단계별 세부 진행 현황 가시성 확보



- Discovery부터 DAST까지 이어지는 각 스캔 단계의 통과 여부를 약어로 표시하여 탐지 프로세스의 투명성을 높였함.

04. 스캔 관리 - 스캔 결과



THREAT NAME	TYPE	AFFECTED ASSETS	SEVERITY	CVEs	EPSS	THREAT STATUS	ACTIONS
Missing Security Header: Referer-Policy	Misconfiguration	6	low	N/A	N/A	new	Detail
Missing Security Header: X-Frame-Options	Misconfiguration	6	low	N/A	N/A	new	Detail
Missing Security Header: X-Content-Type-Options	Misconfiguration	6	low	N/A	N/A	new	Detail
CVE-2009-0796 Apache httpd 2.4.7 CVE-903040NS	Vulnerability	1	low	2.6	N/A	new	Detail
Missing Security Header: Permissions-Policy	Misconfiguration	6	low	N/A	N/A	new	Detail
CVE-2013-0847 Apache httpd 2.4.7 CVE-903530e	Vulnerability	1	low	2.1	N/A	new	Detail
CVE-2012-4360 Apache httpd 2.4.7 CVE-90367ed	Vulnerability	1	medium	4.3	N/A	new	Detail
Missing Security Header: Strict-Transport-Security	Misconfiguration	6	medium	N/A	N/A	new	Detail
High-Risk Service: ssh on 313.96.40.22	Exposure	1	medium	N/A	N/A	new	Detail
Missing Security Header: Content-Security-Policy	Misconfiguration	6	medium	N/A	N/A	new	Detail

다각적 상태 분류 및 이전 스캔 비교를 통한 위협 변화 추적

탐지 위협 및 서비스 요약 정보 제공



- 스캔 완료 후 발견된 위협 수, 활성화된 서비스 수, 오픈 포트 수에 대한 종합적인 요약 정보를 제공함.
- 타겟별 상세 결과 페이지를 통해 개별 자산의 보안 상태와 발생한 이슈를 심층적으로 확인할 수 있음.

6단계 스캔 상태 분류 및 실패 사유 관리



- 상태는 Pending, Running, Completed, Partial Success, Failed, Cancelled 등 6가지로 세분화하여 표시됨.
- 일부 타겟만 성공한 'Partial Success'의 경우, 실패 사유를 JSON 형식으로 저장하여 관리자가 정확한 원인을 파악하도록 지원함.

이전 스캔 비교를 통한 보안 이력 추적



- 동일한 자산에 대해 수행된 이전 스캔 결과와의 비교 기능을 통해 보안 위협의 증감 및 변화 추이를 추적함.
- 신규 탐지된 위협이나 조치 완료된 항목을 구분하여 조직의 보안 조치 효율성을 시각적으로 입증할 수 있음.

04. 스캔 관리 - 예약 스캔

Cron 표현식 및 프리셋 기반의 정기 보안 점검 자동화

유연한 스캔 주기 설정 및 Cron 지원

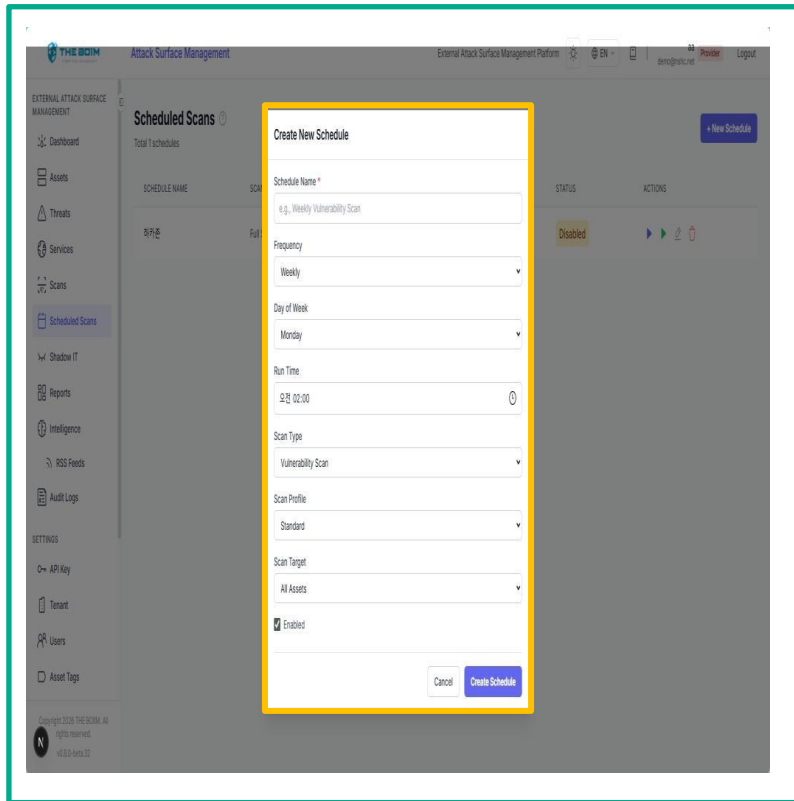
- 매일, 매주, 매월 단위의 직관적인 UI 프리셋을 제공하여 정기적인 보안 스캔을 손쉽게 자동화할 수 있음.
- 커스텀 Cron 표현식을 지원하여 '평일 오전 9시' 등 조직의 운영 정책에 맞춘 세밀한 스캔 일정 설계가 가능함.

스케줄 활성화 및 즉시 실행 제어

- 활성화/비활성화 토글 스위치를 통해 예약된 스케줄을 간편하게 제어하며, 필요시 다음 예약 시간과 관계없이 즉시 스캔을 시작할 수 있음.
- 스케줄 관리 페이지(/easm/schedules)를 통해 다음 실행 예정 시간과 마지막 수행 결과를 한눈에 모니터링함.

목적별 스캔 설정 최적화

- 예약 시 **스캔 타입(Vulnerability 등)**과 **스캔 프로필(Standard 등)**을 지정하여 일관된 점검 수준을 유지함.



A decorative curved line on the left side of the slide, with three dots. The top and bottom dots are dark teal, and the middle dot is white. The numbers 04, 05, and 06 are positioned next to these dots respectively.

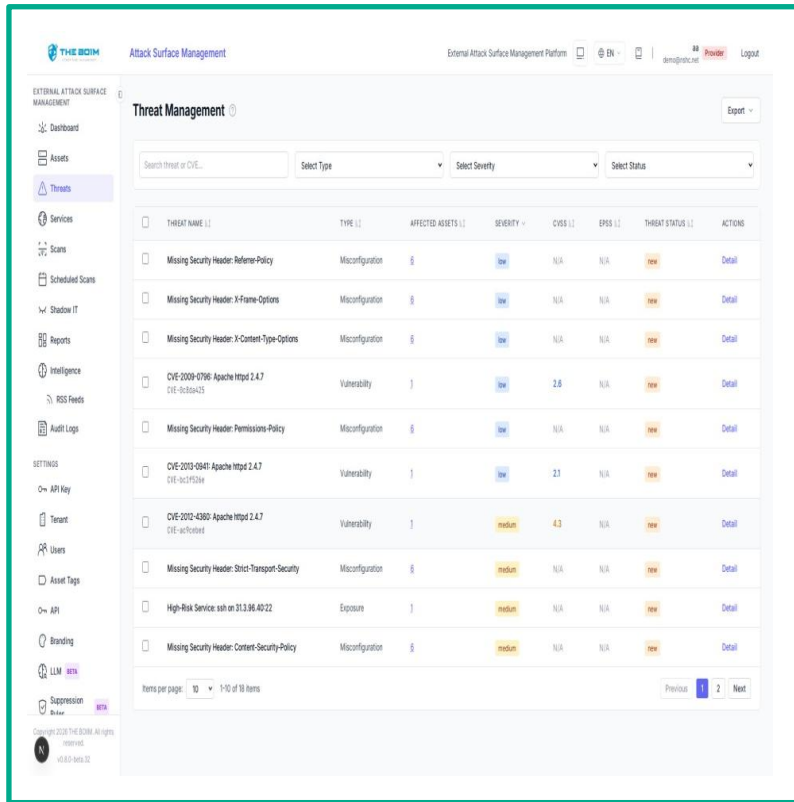
04

05. 위협 관리

목록, 상태 관리, 일괄 처리

06

05. 위험 관리 - 위험 목록



The screenshot shows the 'Threat Management' section of the THE BDM Attack Surface Management platform. The interface includes a sidebar with navigation options like Dashboard, Assets, Threats, Services, Scans, Scheduled Scans, Shadow IT, Reports, Intelligence, RSS Feeds, and Audit Logs. The main area displays a table of threats with columns for Threat Name, Type, Affected Assets, Severity, CVSS, EPSS, Threat Status, and Actions. The table lists various threats such as 'Missing Security Header: Referer-Policy', 'Missing Security Header: X-Frame-Options', 'Missing Security Header: X-Content-Type-Options', 'CVE-2009-0796: Apache Httpd 2.4.7', 'Missing Security Header: Permissions-Policy', 'CVE-2019-0841: Apache Httpd 2.4.7', 'CVE-2012-4380: Apache Httpd 2.4.7', 'Missing Security Header: Strict-Transport-Security', 'High-Risk Service: ssh on 313.96.40.22', and 'Missing Security Header: Content-Security-Policy'. Each row includes a checkbox, a link to details, and a status indicator (e.g., 'new', 'medium').

다각적 필터링 및 통합 검색을 통한 보안 위험 정밀 조회

9개 핵심 컬럼 기반 위험 관리 테이블



- 위험명, 유형, 심각도, CVSS, EPSS, Exploit Status, 영향 자산, 상태, 탐지일 등 9개 항목을 통해 발견된 모든 보안 위험을 상세히 표시함.
- 컬럼 헤더 클릭 시 심각도, CVSS, EPSS, 탐지일 등 다양한 기준에 따른 정렬 기능을 지원함.

다중 필터 및 통합 검색 기능



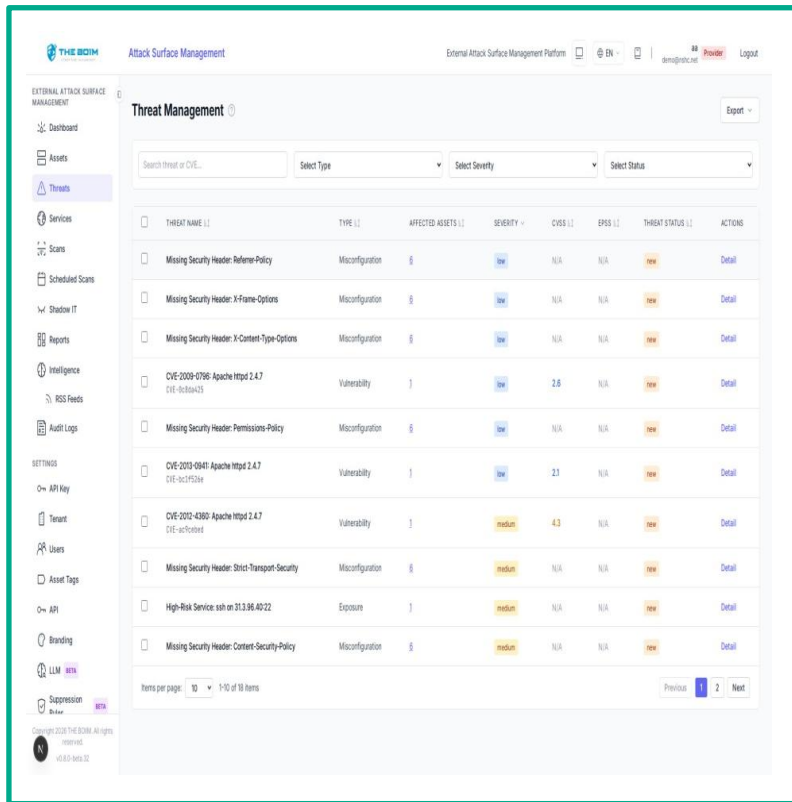
- 심각도, 상태, 타입별 필터링을 지원하여 관리자가 집중해야 할 위험을 빠르게 선별할 수 있음.
- 통합 검색창을 통해 CVE ID, 위험명, 자산명, 자산 IP를 부분 일치 방식으로 신속하게 조회함.

효율적인 데이터 브라우징 및 페이지네이션



- 한 페이지당 10, 20, 50, 100개씩 항목 선택이 가능하여 대량의 위험 데이터를 효율적으로 검토할 수 있음.

05. 위험 관리 - 심각도 이해



The screenshot shows the 'Threat Management' section of THE BDM Attack Surface Management platform. It features a sidebar with navigation options like Dashboard, Assets, Threats, Services, Scans, Scheduled Scans, Shadow IT, Reports, Intelligence, RSS Feeds, Audit Logs, SETTINGS, API Key, Tenant, Users, Asset Tags, API, Branding, LLM, and Suppression. The main area displays a table of threats with columns for Threat Name, Type, Affected Assets, Severity, CVSS, EPSS, Threat Status, and Actions. The table lists various threats, including missing security headers, CVE vulnerabilities, and high-risk services, each with a corresponding severity level (Low, Medium) and status (New).

THREAT NAME	TYPE	AFFECTED ASSETS	SEVERITY	CVSS	EPSS	THREAT STATUS	ACTIONS
Missing Security Header: Referrer-Policy	Misconfiguration	8	Low	N/A	N/A	New	Detail
Missing Security Header: X-Frame-Options	Misconfiguration	8	Low	N/A	N/A	New	Detail
Missing Security Header: X-Content-Type-Options	Misconfiguration	8	Low	N/A	N/A	New	Detail
CVE-2020-0796 Apache Httpd 2.4.7 (CVE-00000000)	Vulnerability	1	Low	2.8	N/A	New	Detail
Missing Security Header: Permissions-Policy	Misconfiguration	8	Low	N/A	N/A	New	Detail
CVE-2019-0941 Apache Httpd 2.4.7 (CVE-00000000)	Vulnerability	1	Low	2.1	N/A	New	Detail
CVE-2019-0941 Apache Httpd 2.4.7 (CVE-00000000)	Vulnerability	1	Medium	4.3	N/A	New	Detail
Missing Security Header: Strict-Transport-Security	Misconfiguration	8	Medium	N/A	N/A	New	Detail
High-Risk Service: ssh on 31.3.86.40:22	Exposure	1	Medium	N/A	N/A	New	Detail
Missing Security Header: Content-Security-Policy	Misconfiguration	8	Medium	N/A	N/A	New	Detail

CVSS 및 EPSS 기반의 객관적 위험 심각도 평가 체계

CVSS 기반 기술적 심각도 분류

- 취약점의 기술적 심각도를 0~10 점수로 표현하며, 점수에 따라 **Critical(9.0~10.0), High(7.0~8.9), Medium(4.0~6.9), Low(0.1~3.9)**로 분류함.



EPSS 기반 악용 확률 예측

- 향후 30일 내 실제 악용될 확률을 0~100% 범위로 예측하며, **매우 높음(50% 이상), 높음(10~50%), 보통(1~10%), 낮음(1% 미만)**으로 평가함.

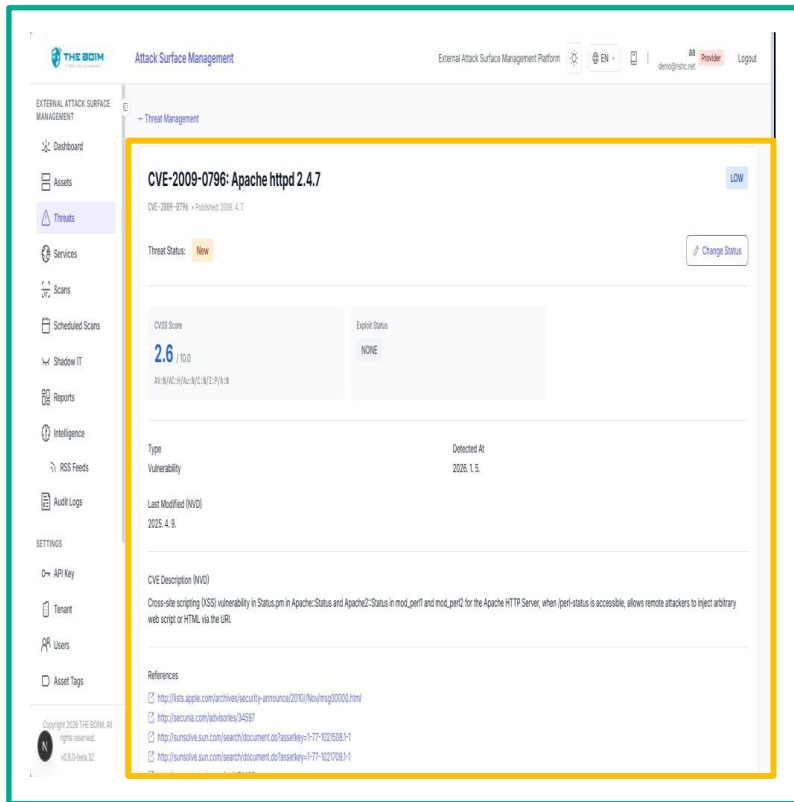


실시간 위험 상태 및 실행 가능성 확인

- 각 위협에 대해 Active, PoC, Published, None 등 Exploit Status를 제공하여 실제 공격 실행 가능성을 함께 파악할 수 있음.



05. 위험 관리 - 위험 상세



6개 핵심 섹션 구성을 통한 위험 분석 및 완화 방법 제공

위험 기본 정보 및 평가 지표



- CVE ID, 위험 유형, 심각도 상태와 함께 CVSS/EPSS 점수 및 Exploit Status를 시각적으로 제공함.
- 최초 탐지일 및 해결 예정일 정보를 통해 위험의 생명 주기를 체계적으로 관리함.

영향 자산 리스트 및 참조 자료



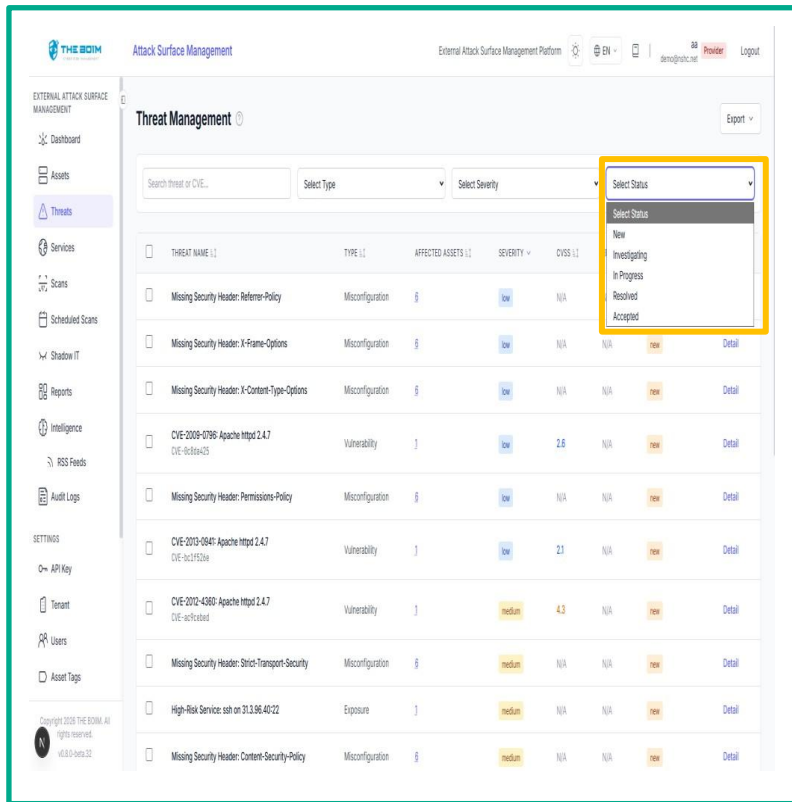
- 해당 위험의 영향을 받는 모든 자산 목록을 자산명, IP, Tier, 위험도와 함께 상세히 제공함.
- NVD 링크, 벤더 보안 공지, 관련 기술 문서 등 신뢰할 수 있는 외부 참조 자료를 연동함.

완화 방법 및 통합 이력 관리



- 패치 적용 방법, 설정 변경 가이드, 우회 방법(Workaround) 등 구체적인 조치 가이드를 제시함.
- 최초 발견부터 상태 변경, 담당자 지정, 자산 추가/제거 등 모든 이력을 타임라인으로 추적함.

05. 위험 관리 - 상태 관리



Attack Surface Management

Threat Management

Select Status

- New
- Investigating
- In Progress
- Resolved
- Accepted

THREAT NAME	TYPE	AFFECTED ASSETS	SEVERITY	CVEs	STATUS	Detailed View
Missing Security Header: Referrer-Policy	Misconfiguration	5	low	N/A	new	Detail
Missing Security Header: X-Frame-Options	Misconfiguration	5	low	N/A	new	Detail
Missing Security Header: X-Content-Type-Options	Misconfiguration	5	low	N/A	new	Detail
CVE-2009-0796: Apache httpd 2.4.7 CVE-6646463	Vulnerability	1	low	2.6	new	Detail
Missing Security Header: Permissions-Policy	Misconfiguration	5	low	N/A	new	Detail
CVE-2013-0847: Apache httpd 2.4.7 CVE-6646463	Vulnerability	1	low	2.3	new	Detail
CVE-2012-4360: Apache httpd 2.4.7 CVE-6646463	Vulnerability	1	medium	4.0	new	Detail
Missing Security Header: Strict-Transport-Security	Misconfiguration	5	medium	N/A	new	Detail
High-Risk Service: ssh on 31.3.96.40:22	Exposure	1	medium	N/A	new	Detail
Missing Security Header: Content-Security-Policy	Misconfiguration	5	medium	N/A	new	Detail

6단계 상태 분류를 통한 위협 대응 생명주기 관리 및 리스크 최적화

6단계 위협 대응 상태 정의

- 발견된 위협은 New(미검토), Investigating(조사 중), In Progress(조치 중), Resolved(해결 완료) 단계로 관리됨.
- 비즈니스 사유에 따른 Accepted(위험 수용) 및 오탐 처리를 위한 Ignored(무시) 상태를 지원함.

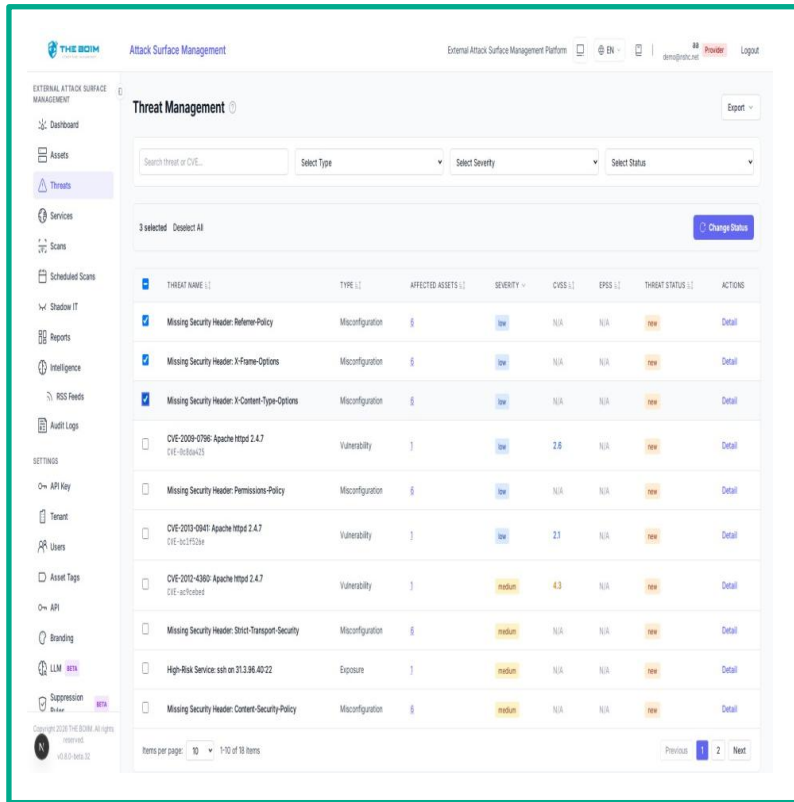
표준 상태 전환 흐름 및 분기 프로세스

- 위협 대응은 New → Investigating → In Progress → Resolved 순서의 표준 워크플로우를 따릅니다.
- 조사 단계에서 판단에 따라 Ignored(오탐) 또는 Accepted(위험 수용) 상태로 분기하여 처리할 수 있음.

위험도 계산 자동 제외 및 최신화

- Resolved 또는 Ignored 상태로 변경된 위협은 자산 및 조직의 전체 위험도 점수 계산에서 즉시 제외됨.
- 이를 통해 실제 대응이 필요한 유효 위협에 대한 리스크 지표만을 정확하게 유지함.

05. 위험 관리 - 일괄 처리



The screenshot shows the 'Threat Management' interface of THE BCM Attack Surface Management. The interface includes a sidebar with navigation options like Dashboard, Assets, Threats, Services, Scans, Scheduled Scans, Shadow IT, Reports, Intelligence, RSS Feeds, and Audit Logs. The main area displays a table of threats with columns for Threat Name, Type, Affected Assets, Severity, CVEs, EPSS, Threat Status, and Actions. Three threats are selected, and a 'Change Status' button is visible. The table lists various threats, including missing security headers, CVEs, and high-risk services.

THREAT NAME	TYPE	AFFECTED ASSETS	SEVERITY	CVEs	EPSS	THREAT STATUS	ACTIONS
☒ Missing Security Header: Referrer-Policy	Misconfiguration	6	low	N/A	N/A	new	Detail
☒ Missing Security Header: X-Frame-Options	Misconfiguration	6	low	N/A	N/A	new	Detail
☒ Missing Security Header: X-Content-Type-Options	Misconfiguration	6	low	N/A	N/A	new	Detail
☐ CVE-2009-0796: Apache Httpd 2.4.7 (CVE-680a425)	Vulnerability	1	low	2.8	N/A	new	Detail
☐ Missing Security Header: Permissions-Policy	Misconfiguration	6	low	N/A	N/A	new	Detail
☐ CVE-2019-0941: Apache Httpd 2.4.7 (CVE-8c1f528e)	Vulnerability	1	low	2.1	N/A	new	Detail
☐ CVE-2019-4380: Apache Httpd 2.4.7 (CVE-verified)	Vulnerability	1	medium	4.3	N/A	new	Detail
☐ Missing Security Header: Strict-Transport-Security	Misconfiguration	6	medium	N/A	N/A	new	Detail
☐ High-Risk Service: ssh on 31.38.40.22	Exposure	1	medium	N/A	N/A	new	Detail
☐ Missing Security Header: Content-Security-Policy	Misconfiguration	6	medium	N/A	N/A	new	Detail

다중 위험 상태의 동시 변경 및 트랜잭션 기반 데이터 보호



대량 위험 선택 및 구간 선택 기능

- 체크박스를 통한 개별 선택뿐만 아니라 Shift+클릭을 이용해 최대 100개까지 위험 항목을 한 번에 구간 선택할 수 있음.
- 선택된 위험들은 일괄 상태 변경 모달을 통해 새로운 상태로 일시에 전환됨.



변경 사유 기록 및 시간 자동 등록

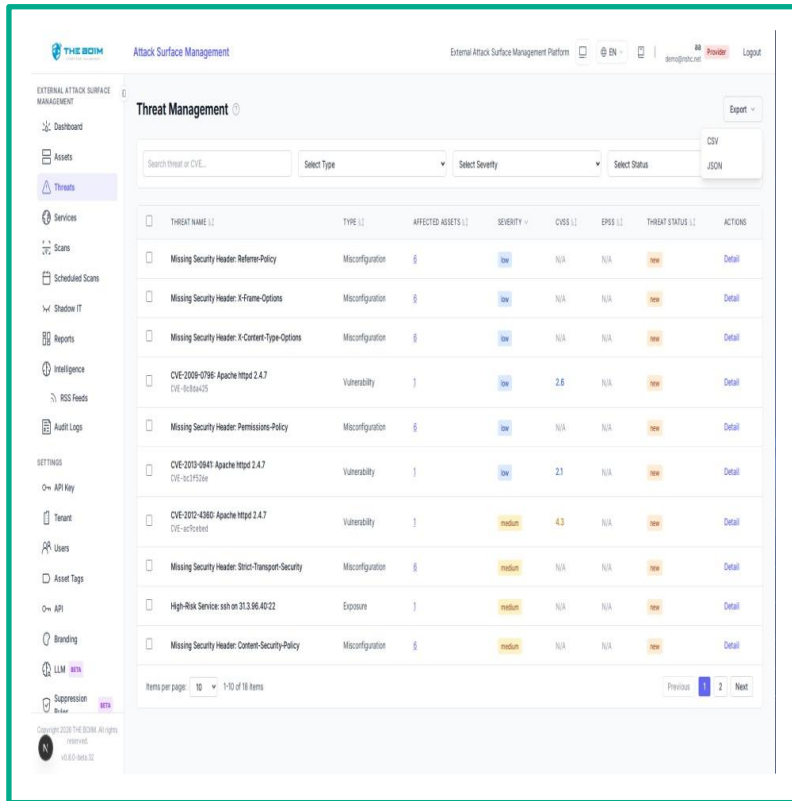
- 상태 변경 시 변경 사유 코멘트를 필수로 입력하여 조치 이력의 투명성을 확보함.
- - Resolved 상태로 변경 시 시스템이 현재 시간을 'resolvedAt' 필드에 자동으로 기록하여 정확한 해결 시점을 관리함.



트랜잭션 보장을 통한 데이터 일관성 유지

- 모든 위험의 상태 변경 및 위험도 재계산은 단일 트랜잭션 내에서 수행됨.
- 처리 중 실패 발생 시 전체 작업을 롤백(Rollback)하여 데이터의 무결성과 일관성을 엄격히 보장함.

05. 위험 관리 - 내보내기



The screenshot shows the 'Threat Management' page of THE BOM Attack Surface Management. It features a sidebar with navigation options like Dashboard, Assets, Threats, Services, Scans, Scheduled Scans, Shadow IT, Reports, Intelligence, RSS Feeds, Audit Logs, Settings, API Key, Tenant, Users, Asset Tags, API, Branding, LLM, and Suppression. The main area displays a table of threats with columns for Threat Name, Type, Affected Assets, Severity, CVSS, EPSS, Threat Status, and Actions. The table lists various threats such as 'Missing Security Header: Referer-Policy', 'Missing Security Header: X-Frame-Options', 'Missing Security Header: X-Content-Type-Options', 'CVE-2008-0796: Apache Httpd 2.4.7', 'Missing Security Header: Permissions-Policy', 'CVE-2010-0847: Apache Httpd 2.4.7', 'CVE-2012-4380: Apache Httpd 2.4.7', 'Missing Security Header: Strict-Transport-Security', 'High-Risk Service: ssh on 31.3.86.40:22', and 'Missing Security Header: Content-Security-Policy'. Each row includes a checkbox, a link to 'Detail', and a 'Download' button. The bottom of the table shows 'Items per page: 10' and '1-10 of 10 items'.

THREAT NAME	TYPE	AFFECTED ASSETS	SEVERITY	CVSS	EPSS	THREAT STATUS	ACTIONS
☐ Missing Security Header: Referer-Policy	Misconfiguration	8	low	N/A	N/A	new	Detail
☐ Missing Security Header: X-Frame-Options	Misconfiguration	8	low	N/A	N/A	new	Detail
☐ Missing Security Header: X-Content-Type-Options	Misconfiguration	8	low	N/A	N/A	new	Detail
☐ CVE-2008-0796: Apache Httpd 2.4.7 CVE-0c38a425	Vulnerability	1	low	2.6	N/A	new	Detail
☐ Missing Security Header: Permissions-Policy	Misconfiguration	8	low	N/A	N/A	new	Detail
☐ CVE-2010-0847: Apache Httpd 2.4.7 CVE-8c1f550e	Vulnerability	1	low	2.1	N/A	new	Detail
☐ CVE-2012-4380: Apache Httpd 2.4.7 CVE-8c1f550e	Vulnerability	1	medium	4.3	N/A	new	Detail
☐ Missing Security Header: Strict-Transport-Security	Misconfiguration	8	medium	N/A	N/A	new	Detail
☐ High-Risk Service: ssh on 31.3.86.40:22	Exposure	1	medium	N/A	N/A	new	Detail
☐ Missing Security Header: Content-Security-Policy	Misconfiguration	8	medium	N/A	N/A	new	Detail

CSV 및 JSON 형식 지원을 통한 유연한 위험 데이터 활용



15개 필드를 포함한 상세 CSV 추출

- 위험명, 심각도, CVE ID, CVSS/EPSS 점수, 영향 자산 목록, 조치 방법 등 15개 핵심 필드를 포함한 상세 리포트를 생성함.
- 현재 적용된 필터 조건(심각도, 상태 등)이 그대로 반영되어 필요한 데이터만 선별적으로 내보낼 수 있음.



엑셀 환경을 고려한 데이터 인코딩 최적화

- CSV 내보내기 시 UTF-8 BOM 인코딩을 적용하여, Microsoft Excel에서 파일을 열었을 때 발생하는 한글 깨짐 현상을 원천 방지함.
- 보안 운영자가 별도의 인코딩 변환 작업 없이 즉시 보고서 작성에 데이터를 활용할 수 있도록 편의성을 제공함.



개발 및 자동화 친화적인 JSON 포맷 지원

- 전체 위험 데이터를 계층 구조인 JSON 형식으로 추출하여 타 보안 솔루션(SIEM/SOAR)과의 연동을 지원함.
- 가독성을 높인 Pretty Print 형식을 적용하여 데이터 구조 파악 및 디버깅 효율을 높였함.



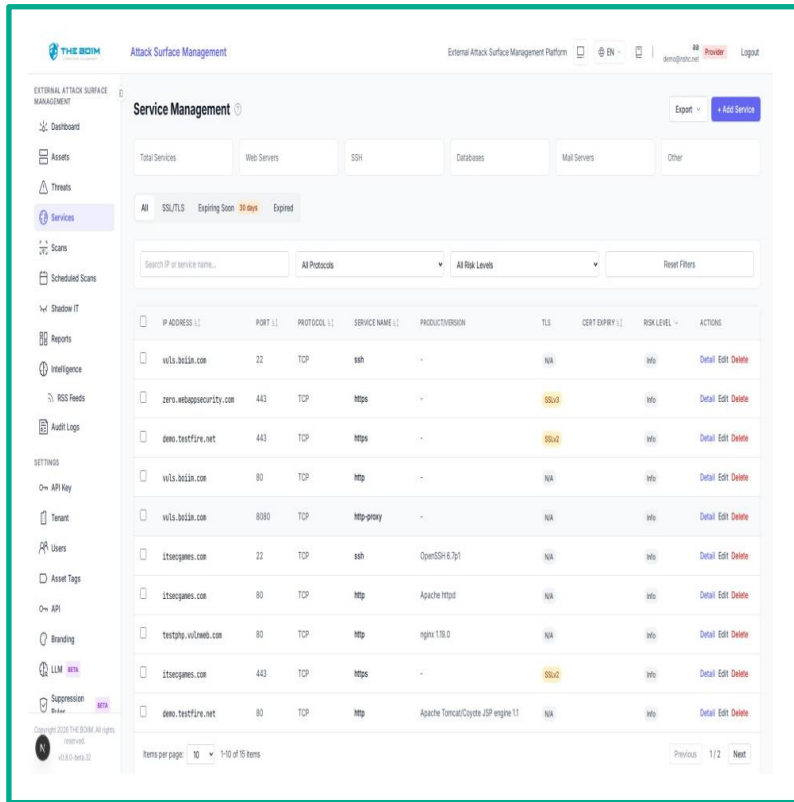
05

06. 서비스 관리

포트, SSL/TLS, 보안 헤더, CVE

07

06. 서비스 관리 - 서비스 목록



IP ADDRESS	PORT	PROTOCOL	SERVICE NAME	PRODUCT/VERSION	TLS	CERT EXPIRY	RISK LEVEL	ACTIONS
vuln.betish.com	22	TCP	ssh	-	N/A	N/A	Info	Detail Edit Delete
zero.webappsecrity.com	443	TCP	https	-	SSLv3	N/A	Info	Detail Edit Delete
demo.testfire.net	443	TCP	https	-	SSLv2	N/A	Info	Detail Edit Delete
vuln.betish.com	80	TCP	http	-	N/A	N/A	Info	Detail Edit Delete
vuln.betish.com	8080	TCP	http-proxy	-	N/A	N/A	Info	Detail Edit Delete
111111111111.com	22	TCP	ssh	OpenSSH 8.7p1	N/A	N/A	Info	Detail Edit Delete
111111111111.com	80	TCP	http	Apache/2.4.18	N/A	N/A	Info	Detail Edit Delete
testapi.vulnweb.com	80	TCP	http	nginx/1.19.0	N/A	N/A	Info	Detail Edit Delete
111111111111.com	443	TCP	https	-	SSLv2	N/A	Info	Detail Edit Delete
demo.testfire.net	80	TCP	http	Apache Tomcat/Coyote JSP engine/1.1	N/A	N/A	Info	Detail Edit Delete

네트워크 서비스의 자동 분류 및 상세 속성 모니터링

5개 주요 카테고리별 실시간 통계



- 스캔으로 탐지된 전체 서비스를 전체, 웹 서버, SSH, 데이터베이스, 메일 서버 등 5개 핵심 카테고리로 자동 분류하여 수량을 표시함.
- 각 카테고리 클릭 시 해당 서비스 유형에 최적화된 필터링 결과를 즉시 확인할 수 있음.

8개 속성 중심의 상세 서비스 테이블



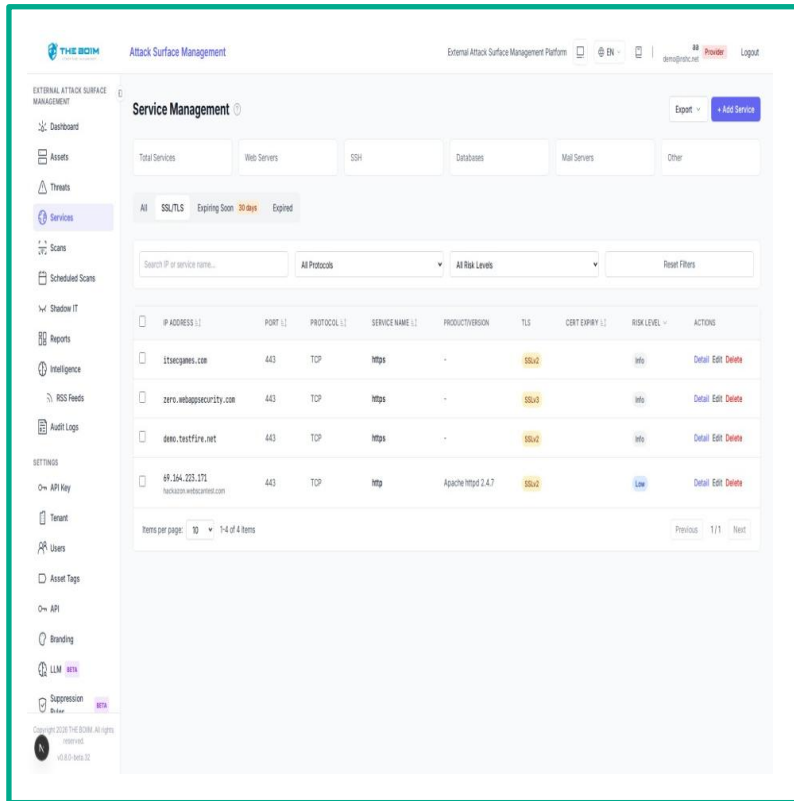
- IP 주소, 포트, 프로토콜, 서비스명, 제품/버전, TLS 지원, SSL 만료일, 위험도 등 8개 컬럼을 통해 서비스 상세 정보를 제공함.
- 프로토콜 및 위험도 기반의 필터 기능과 제품명 통합 검색을 통해 특정 자산의 노출 상태를 신속하게 조회함.

보안 인증 및 암호화 상태 시각화



- TLS 지원 여부를 활성화(녹색) 및 비활성화(회색) 배지로 구분 표시하여 자산의 암호화 통신 적용 상태를 직관적으로 파악함.
- SSL 인증서의 만료 예정일 정보를 함께 제공하여 보안 인증 공백이 발생하지 않도록 사전 관리를 지원함.

06. 서비스 관리 - SSL/TLS 필터



The screenshot displays the 'Service Management' section of the THE BDM Attack Surface Management platform. It features a sidebar with navigation options like Dashboard, Assets, Threats, Services, Scans, Scheduled Scans, Shadow IT, Reports, Intelligence, RSS Feeds, Audit Logs, Settings, Tenant, Users, Asset Tags, API, Branding, LLM, and Suppression. The main content area shows a table of services with columns for IP Address, Port, Protocol, Service Name, Product/Version, TLS, Cert Expiry, Risk Level, and Actions. The table lists four services: 1tsaegames.com, zern.webappsecrity.com, dees.testfire.net, and 48.364.223.371. The first three services are marked as 'SSL/TLS' with a yellow risk level, while the last one is marked as 'Apache/Httpd 2.4.7' with a 'Low' risk level. The interface also includes filters for 'All', 'SSL/TLS', 'Expiring Soon', and 'Expired'.

인증서 만료 주기별 색상 분류를 통한 실시간 긴급도 시각화

4개 탭 기반의 SSL/TLS 상태 필터링

- 전체, SSL/TLS, 만료 임박(Cert Expiry), 만료됨 등 4개 전용 탭을 통해 서비스 인증 상태별로 신속하게 필터링할 수 있음.
- '만료 임박' 탭은 현재 일자 기준으로 만료일이 30일 이내인 서비스를 별도로 추출하여 경고를 제공함.

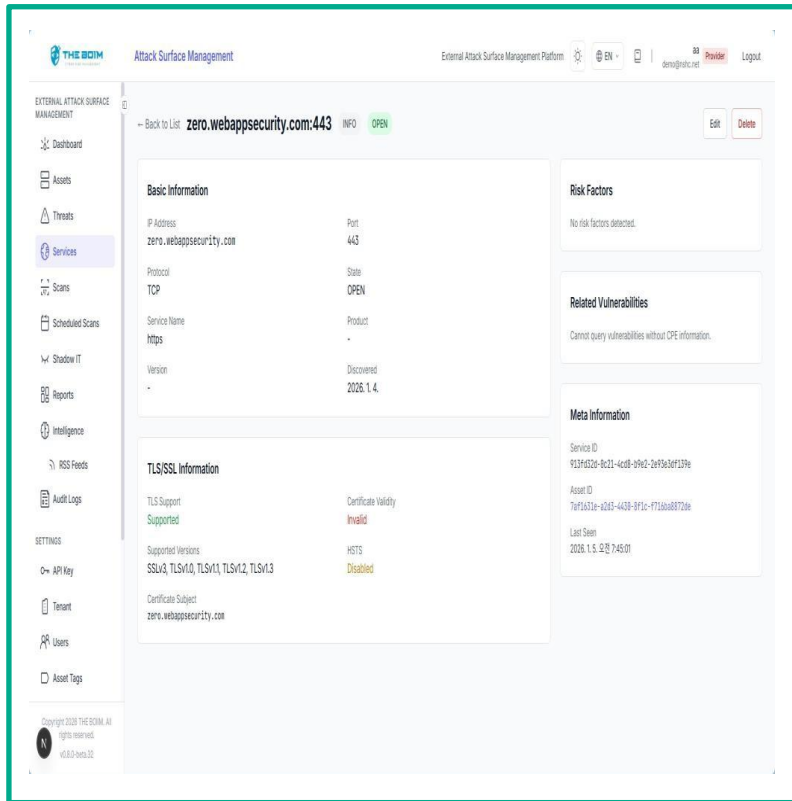
D-day 기준 5단계 시각적 긴급도 구분

- D-90 이상(녹색), D-30~89(주황색), D-8~29(빨간색), D-1~7(진한 빨간색), 만료됨(가장 진한 빨간색) 등 5단계 색상 체계를 적용함.
- 직관적인 색상 구분을 통해 보안 관리자가 최우선으로 갱신해야 할 인증서를 즉각 식별할 수 있도록 지원함.

만료된 서비스에 대한 경고

- 인증서 만료일이 현재일보다 이전인 서비스를 '만료됨' 상태로 분류하고 시각적 경고를 표시하여 보안 공백을 방지함.

06. 서비스 관리 - 서비스 상세



The screenshot displays the 'Attack Surface Management' interface for 'zero.webappsecurity.com:443'. The left sidebar contains navigation options: Dashboard, Assets, Threats, Services (selected), Scans, Scheduled Scans, Shadow IT, Reports, Intelligence, RSS Feeds, Audit Logs, Settings, API Key, Tenant, Users, and Asset Tags. The main content area is divided into several sections: 'Basic Information' (IP Address: zero.webappsecurity.com, Port: 443, Protocol: TCP, State: OPEN, Service Name: https, Product: -, Version: 2026.1.4), 'Risk Factors' (No risk factors detected), 'Related Vulnerabilities' (Cannot query vulnerabilities without CPE information), 'Meta Information' (Service ID: 913f4d26-8e22-4c08-99d2-3a95a3ef139e, Asset ID: 7ef1631e-e2d5-4438-9f1c-7f12aa8870de, Last Seen: 2026.1.5. 오전 7:45:01), and 'TLS/SSL Information' (TLS Support: Supported, Certificate Validity: Invalid, Supported Versions: SSLv3, TLSv1.0, TLSv1.1, TLSv1.2, TLSv1.3, HSTS: Disabled, Certificate Subject: zero.webappsecurity.com).

4개 탭 구성을 통한 서비스별 기술 속성 및 취약점 식별 정보 제공

4개 핵심 탭 중심의 상세 정보 분석

- 서비스 상세 페이지는 기본 정보, TLS/SSL, HTTP 정보, CPE/CVE 등 4개 탭으로 구성되어 자산의 서비스 특성을 다각도로 분석함.
- 기본 정보 탭에서는 IP 주소, 포트, 프로토콜 상태와 함께 서비스명, 제품명, 버전, 발견일, 최종 확인 일시 등을 상세히 표시함.



서비스 식별을 위한 배너 및 기술 스택 감지

- **배너(Banner) 분석:** 응답 텍스트 정보를 분석하여 소프트웨어 제품명, 버전, OS 정보 추출
- **기술 스택 가시화:** 감지된 기술 스택 결과를 시각화하여 자산의 구성 환경을 직관적으로 파악

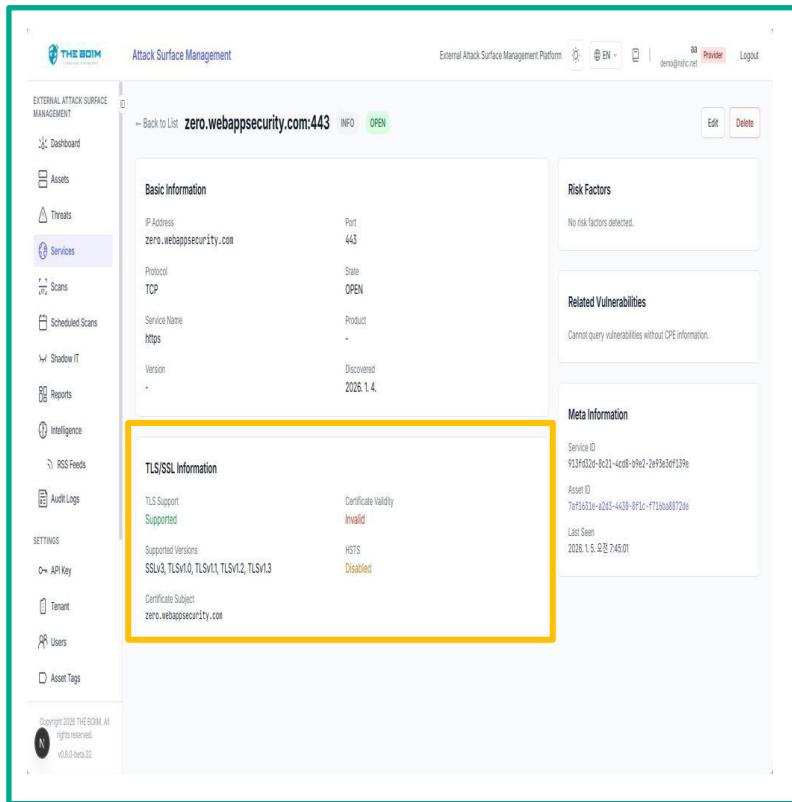


NIST 표준 CPE 기반의 CVE 자동 연동

- **고유 식별:** 탐지된 소프트웨어를 NIST 표준 형식인 CPE(Common Platform Enumeration)로 식별
- **취약점 자동 조회:** 식별된 CPE를 NVD API와 연동하여 해당 제품의 CVE 정보를 자동으로 조회



06. 서비스 관리 - TLS/SSL 검증



The screenshot displays the 'Attack Surface Management' interface for 'zero.webappsecurity.com:443'. The 'TLS/SSL Information' section is highlighted with a yellow box. It shows the following details:

Item	Status
TLS Support	Supported
Certificate Validity	Invalid
Supported Versions	SSLv3, TLSv1.0, TLSv1.1, TLSv1.2, TLSv1.3
HSTS	Disabled
Certificate Subject	zero.webappsecurity.com

인증서 유효성 및 프로토콜 버전 분석을 통한 암호화 통신 보안 강화

인증서 상세 정보 및 유효성 점검



- **인증서 정보:** 주체(CN, O, C 등), 발급자, 유효 시작일 및 만료일, 서명 알고리즘 제공
- **유효성 평가:** 유효, 만료, 자체 서명(Self-signed), 호스트 불일치 등 인증서 상태 정밀 분석

프로필별 TLS 프로토콜 보안 등급 분류



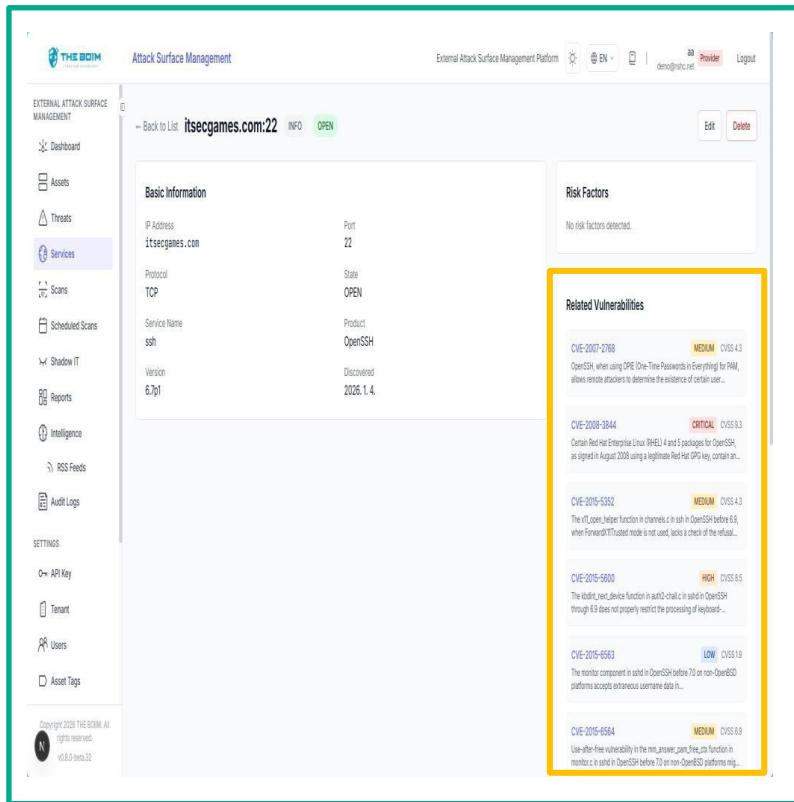
- **권장 버전:** 보안성이 우수한 TLS 1.3 및 TLS 1.2 버전을 '안전' 등급으로 평가 및 활성화 권장
- **취약 버전:** 취약점이 발견된 TLS 1.1, TLS 1.0 및 SSL 3.0/2.0 버전은 '취약' 등급으로 분류하여 사용 금지 가이드 제공

암호 스위트(Cipher Suite) 안전성 평가



- **안전한 스위트:** ECDHE+AES_GCM+SHA256 등 강력한 암호화 알고리즘 조합 식별
- **취약한 스위트:** 보안에 취약한 RC4, DES 등의 알고리즘 사용 여부를 탐지하여 조치 권고

06. 서비스 관리 - CPE/CVE 조회



The screenshot displays the THE BROOM Attack Surface Management platform. The main view shows the 'Basic Information' for the service 'itsecgames.com:22'. The service is identified as 'OpenSSH' with a version of '6.7p1' discovered on '2025. 1. 4'. A sidebar on the left contains navigation options like Dashboard, Assets, Threats, Services, Scans, Scheduled Scans, Shadow IT, Reports, Intelligence, RSS Feeds, Audit Logs, Settings, API Key, Tenant, Users, and Asset Tags. A 'Related Vulnerabilities' section is highlighted with a yellow box, listing several CVEs with their severity levels and descriptions.

CVE ID	Severity	CVSS Score	Description
CVE-2007-2769	MEDIUM	CVSS 4.3	OpenSSH, when using CPE (One-Time Passwords in Everything) for PAM, allows remote attackers to determine the existence of certain user...
CVE-2008-3844	CRITICAL	CVSS 9.3	Certain Red Hat Enterprise Linux (RHEL) 4 and 5 packages for OpenSSH, as signed in August 2008 using a legitimate Red Hat GPG key, contain an...
CVE-2015-5302	MEDIUM	CVSS 4.3	The vt_Linux_Libkey function in channels.c in OpenSSH before 6.9, when ForwardTunnel mode is not used, lacks a check of the relay...
CVE-2015-5600	HIGH	CVSS 8.5	The libssh2_session_function in auth2-chall.c in OpenSSH through 6.9 does not properly restrict the processing of keyboard...
CVE-2015-6563	LOW	CVSS 1.9	The monitor component in sshd in OpenSSH before 7.0 on non-OpenBSD platforms accepts extraneous username data in...
CVE-2015-6564	MEDIUM	CVSS 6.9	Use-after-free vulnerability in the non_unix_pam_free_cfu function in monitor.c in OpenSSH before 7.0 on non-OpenBSD platforms m...

NVD API 연동을 통한 서비스별 관련 CVE 정보의 자동 식별 및 연결

CPE 생성 및 NVD API 자동 쿼리 메커니즘

- **CPE 생성:** 서비스 스캔 시 탐지된 제품명과 버전 정보를 기반으로 표준화된 CPE 코드 생성
- **자동 조회:** 생성된 CPE를 바탕으로 NVD API에 실시간 쿼리를 전송하여 관련 CVE 목록 자동 확보



서비스별 연관 취약점 정보 구성 항목

- **식별 정보:** CVE ID, 취약점 요약 설명, 게시일 및 최종 수정일 정보 제공
- **평가 지표:** CVSS 점수 및 벡터(Vector) 정보를 연동하여 기술적 위험도 가시화
- **상세 참조:** 취약점별 상세 분석 및 조치 방안 확인을 위한 외부 참조 링크 연동



지속적인 취약점 모니터링 및 자동 갱신

- **재조회 주기:** 서비스 최초 발견 시점 및 매일 정기적인 API 호출을 통해 최신 취약점 정보 유지
- **위험 생성:** 조회된 취약점 정보를 기반으로 시스템 내 관리 대상 위협을 자동으로 생성 및 등록





06

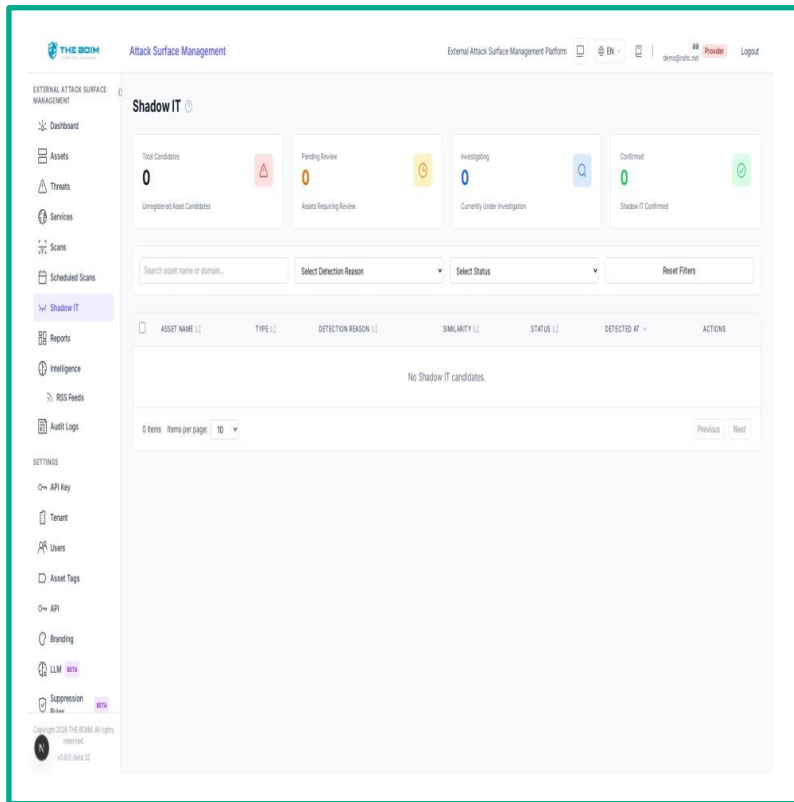
07. Shadow IT

탐지, 검토, 자산 변환, 화이트리스트

08

07. Shadow IT – shadow IT란?

미인가 IT 자산의 자동 탐지를 통한
보안 사각지대 및 컴플라이언스 리스크 해소



Shadow IT의 정의 및 분류 기준



- **정의:** 조직의 IT 부서나 보안팀이 공식적으로 인지하지 못한 채 운영 중인 모든 IT 자산
- **분류:** 디스커버리 과정에서 발견되었으나 자산 관리 시스템에 미등록된 모든 자산을 후보로 분류

전형적인 새도우 IT 발생 사례



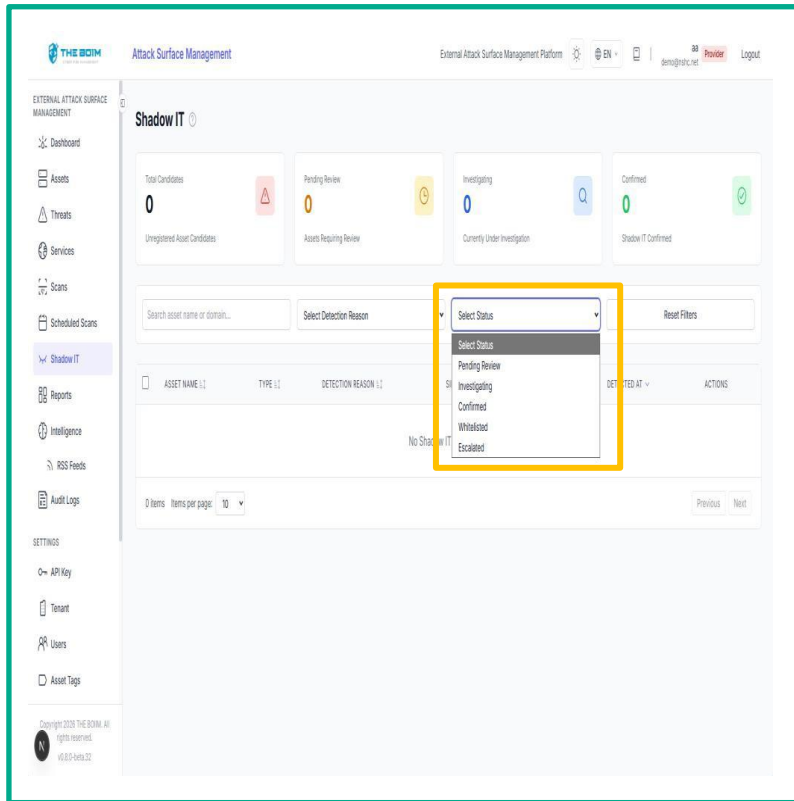
- **테스트 및 캠페인:** 개발팀의 테스트용 클라우드 인스턴스, 마케팅팀의 캠페인용 서버도메인
- **외부 및 레거시:** 외주업체의 임시 서버, 퇴사자가 관리하던 레거시 시스템
- **공격 유사:** 타이포스쿼팅(Typosquatting) 공격용 유사 도메인 등

미관리 자산에 따른 보안 리스크



- **취약점 노출:** 관리 부재로 인한 보안 패치 누락 및 보안성이 낮은 오래된 소프트웨어 실행
- **규제 미준수:** GDPR/PCI-DSS 등 컴플라이언스 미충족 및 민감 데이터의 비인가 노출 위험

07. Shadow IT – 후보 검토



통계 기반의 후보 모니터링 및 6개 컬럼 중심의 상세 검토 환경 제공

4개 핵심 통계 카드를 통한 현황 파악

- **현황 지표:** Total Candidates(전체 후보), Pending Review(검토 대기), Investigating(조사 중), Confirmed(확정) 수치 표시
- **가시성:** 미등록 자산의 처리 단계별 수량을 실시간으로 시각화하여 관리 집중도 향상

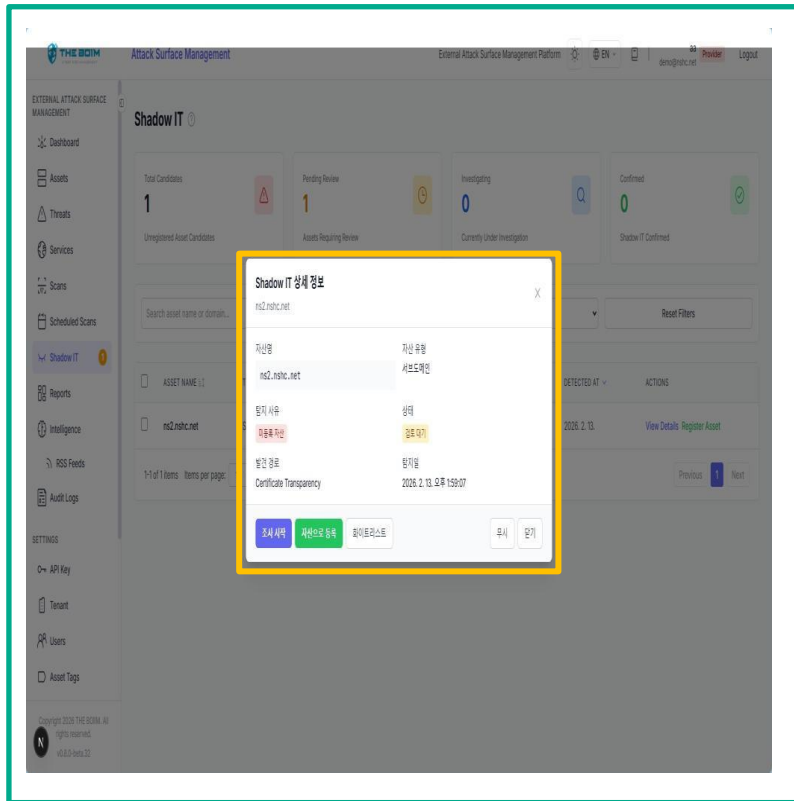
6개 속성 기반의 상세 검토 테이블

- **정보 항목:** 자산명, 타입, 탐지 사유, 유사도, 상태, 탐지일 정보 제공
- **상세 조회:** 상세 모달을 통해 해당 후보의 WHOIS 및 DNS 정보를 추가로 조회하여 판정 근거 확보

탐지 사유 분류 및 최종 판정 워크플로우

- **탐지 사유:** Unregistered(일반 미등록), Typosquatting(유사 도메인), Expired Domain(만료 재등록), Cloud Resource(클라우드 자산)로 구분
- **최종 판정:** 검토 결과에 따라 정식 자산 등록, 화이트리스트 제외, 또는 에스컬레이션(Escalated) 등으로 판정 처리

07. Shadow IT – 자산 변환



검증된 후보의 정식 자산 전환을 통한 통합 보안 관리 체계 편입

Shadow IT 자산의 정식 등록 프로세스

- **변환 정의:** Confirmed(확정) 상태의 후보를 시스템의 정식 관리 자산으로 전환하는 절차
- **상태 동기화:** 변환 완료 시 후보 상태가 Confirmed로 변경되며, 생성된 자산 ID가 'convertedAssetId' 필드에 자동 저장



자산 등록 시 필수 설정 및 입력 항목

- **기본 정보:** 자산명, 타입, IP 주소(후보 정보 기반 자동 입력), Classification 입력
- **관리 속성:** Tier(기본값: tier3), Owner(담당자), Department(부서), Tags, Description 지정



정식 등록에 따른 보안 운영 효과

- **통합 관리:** 자산 관리 시스템에 정식 등록되어 타 자산과 동일한 보안 정책 적용
- **스캔 대상 포함:** 등록 즉시 차기 스캔 대상에 포함되어 지속적인 취약점 및 위협 탐지 수행



A decorative curved line on the left side of the slide, with three dots. The top and bottom dots are dark teal, and the middle dot is white. The numbers 07, 08, and 09 are positioned next to these dots respectively.

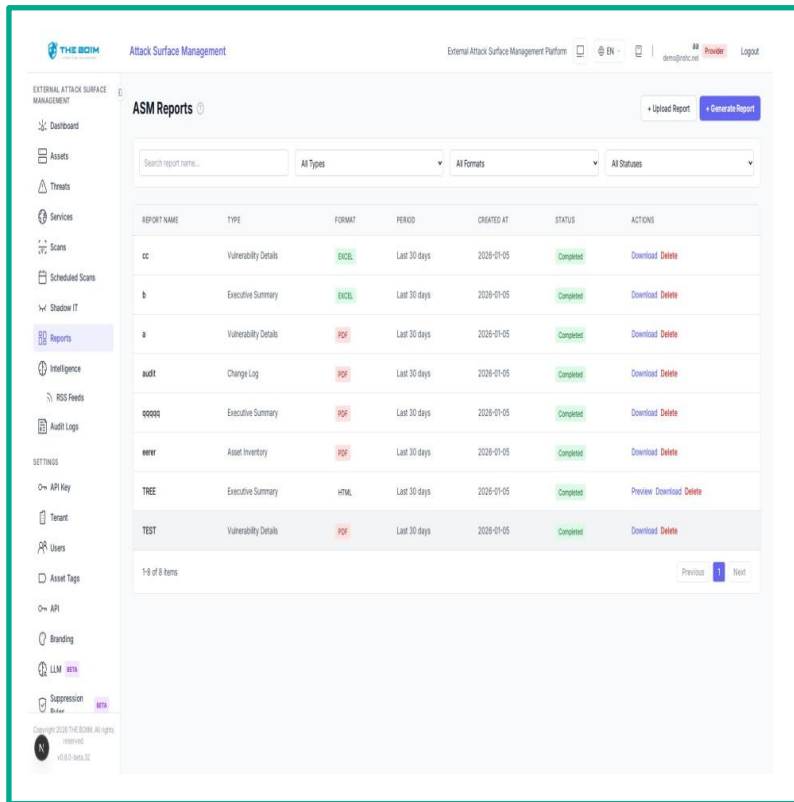
07

08. 보고서

유형, 생성, 예약, compliance

09

08. 보고서 - 보고서 유형



3종의 맞춤형 보고서 제공을 통한 직무별 보안 가시성 확보

Asset Inventory (전체 자산 현황 보고서)



- **주요 내용:** 자산 목록, 자산 분포 현황, 자산 변경 이력, 서비스 및 위협 요약 정보 제공
- **활용 대상:** IT 자산 관리자 및 인프라 운영팀의 전체 자산 가시성 확보에 최적화

Vulnerability Details (상세 취약점 보고서)



- **주요 내용:** 취약점 목록, 자산별 상세 취약점, 조치 가이드(Remediation), 트렌드 분석, CVE 상세 정보 포함
- **활용 대상:** 보안 실무팀 및 침해사고 대응팀의 신속한 위협 분석과 완화 조치 실행 지원

Change Log 및 관리용 보고서



- **주요 내용:** 시스템 내 발생한 주요 변경 사항과 감사 이력(Audit Log) 기반의 변동 정보 제공
- **활용 대상:** 감사 담당자 및 경영진의 보안 정책 준수 여부 점검 및 의사결정 자료로 활용

08. 보고서 - 보고서 생성

다양한 필터 옵션과 백그라운드 처리를 통한 맞춤형 보고서 생성

보고서 기본 설정 및 포맷 지정



- **기본 항목:** 보고서명 입력 및 3가지 보고서 유형(Asset Inventory, Vulnerability Details 등) 중 선택
- **출력 포맷:** PDF, Excel(시트당 최대 1,000행 제한), CSV, HTML 형식 지원

기간 및 데이터 필터링 상세 설정

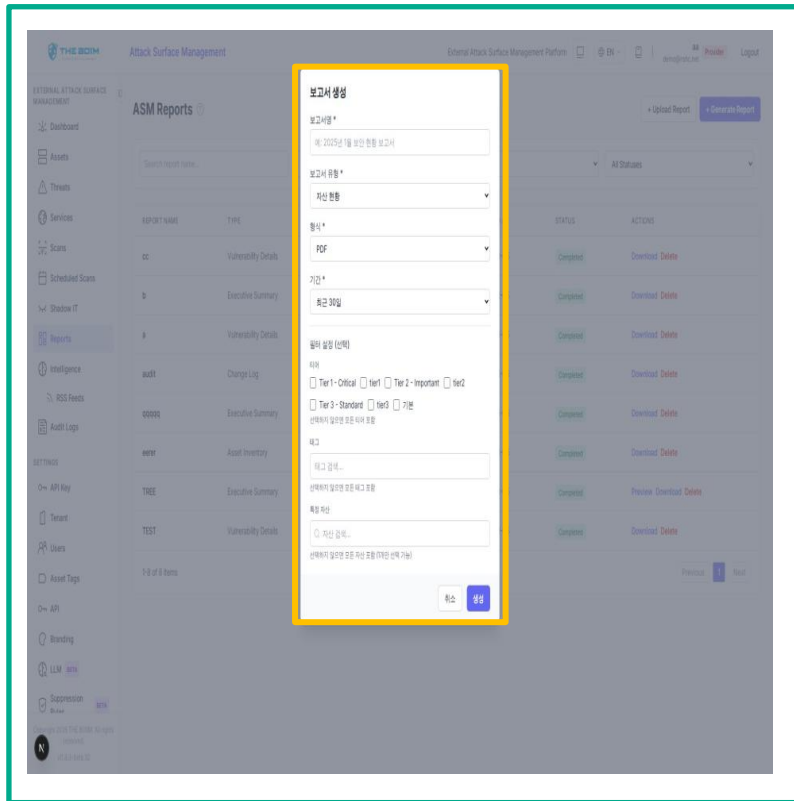


- **기간 유형:** 최근 7일/30일/90일 또는 사용자 정의(Custom) 기간 설정 가능
- **필터 옵션:** 자산 Tier(Tier 1/2/3/미분류), 위협 심각도, 태그, 특정 자산 ID 지정 지원

보고서 생성 상태 모니터링 및 완료



- **백그라운드 처리:** 생성 버튼 클릭 시 서버에서 작업이 수행되며 리스트에서 실시간 상태 확인
- **4단계 상태 분류:** Pending(대기 중), Generating(생성 중), Completed(완료), Failed(실패) 상태 제공



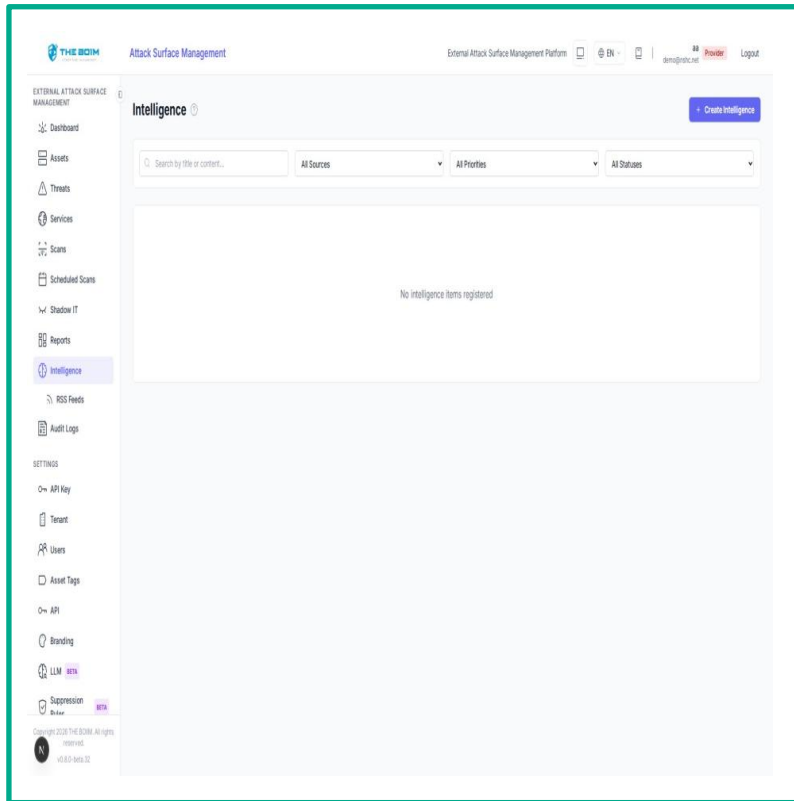
08

09. 인텔리전스

RSS 피드, 키워드 알림

10

09. 인텔리전스 - 인텔리전스 개요



다양한 보안 소스 통합 및 RSS 피드 기반의 실시간 위협 정보 수집



외부 보안 정보의 실시간 수집 및 모니터링

- 정보 수집: 외부 보안 뉴스, CVE 공지, 위협 인텔리전스 피드(RSS) 자동 구독 및 통합 모니터링
- 자동 탐지: 수집된 정보 내 키워드 매칭을 통해 조직 관련 보안 정보를 자동으로 탐지 및 알림



7개 카테고리 분류 및 보안 소스 다각화

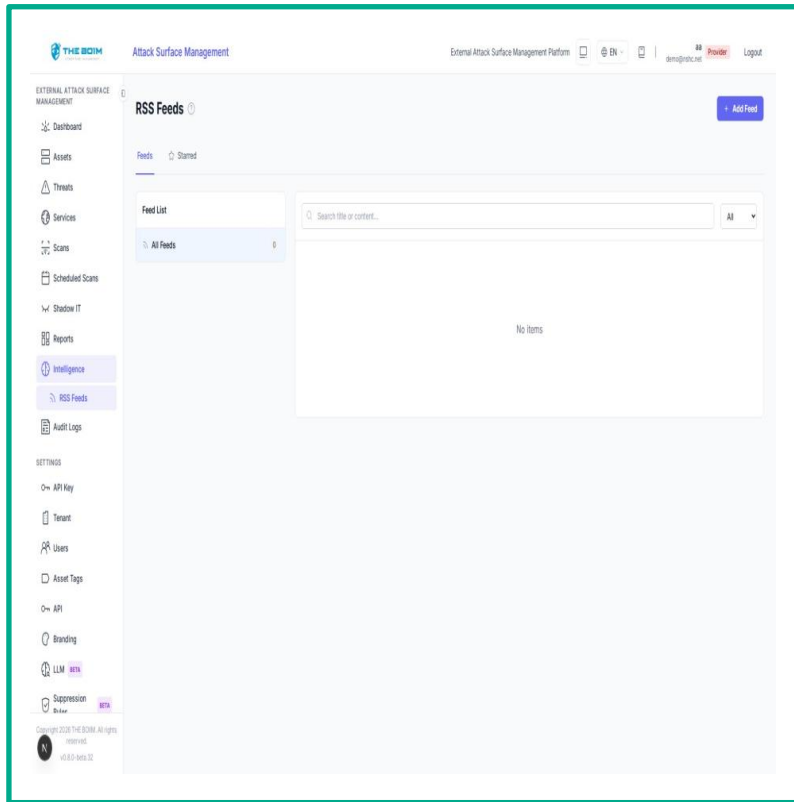
- 카테고리: CVE, Threat, News, Vendor, Blog, Research, Other 등 7개 유형으로 정보 분류
- 신뢰 소스: NVD, CISA, KrCERT 등 국내외 공신력 있는 보안 소스를 단일 화면에서 관리



위협 정보의 능동적 기록 및 상태 관리

- 수동 기록: 'Intelligence Feed' 탭을 통해 관리자가 식별한 위협 정보를 직접 기록 및 관리 가능
- 이용 편의: 각 인텔리전스 항목에 대한 읽음 상태 표시 및 중요 항목 별표(Star) 관리 기능 지원

09. 인텔리전스 - RSS 피드 관리



유연한 갱신 주기 설정 및 상태 모니터링을 통한 최신 위협 정보 유지

RSS 피드 추가 및 핵심 설정 항목

- 필수 입력: 피드 이름, 수집용 URL, 정보 카테고리 지정
- 수집 최적화: 갱신 주기(기본 60분) 및 한 번에 가져올 최대 아이템 수 설정 가능



피드 운영 상태의 시각적 모니터링

- 정상(녹색): 피드가 활성화되어 있으며 자동 갱신이 정상적으로 수행되는 상태
- 오류(빨간색): URL 접근 불가 등 수집 과정에서 문제가 발생한 상태
- 비활성(회색): 관리자에 의해 수집이 일시 중단된 상태

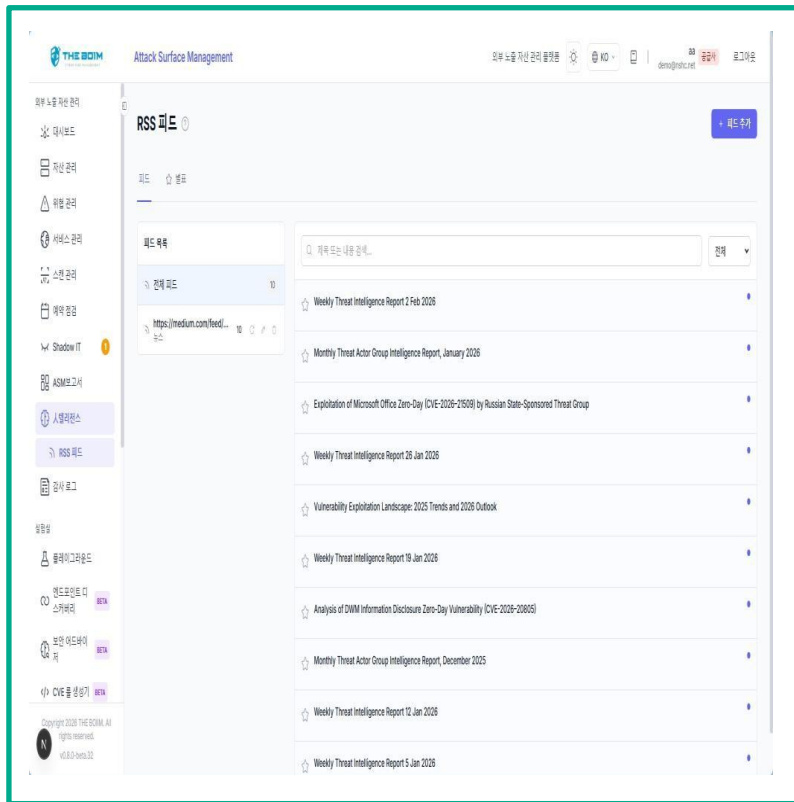


수동 및 자동 수집 제어 기능

- 자동 갱신: 활성화된 피드에 한해 설정된 주기마다 백그라운드에서 신규 정보 수집
- 즉시 수집: 각 피드별 '수동 새로고침' 버튼을 통해 주기와 관계없이 즉시 정보 동기화 지원



09. 인텔리전스 - 피드 아이템 조회 및 관리



개별 피드 아이템의 상세 분석 및 중요도 기반의 체계적 정보 관리

피드 아이템 카드 구성 및 핵심 정보 표시

- **시 항목:** 위협 정보의 제목, 요약 설명, 정보 출처, 발행 시간, 카테고리 태그 제공
- **가독성:** 카드 형태의 인터페이스를 통해 대량의 인텔리전스 정보를 신속하게 브라우징



상세 뷰어 및 정보 활용 기능

- **상세 모드:** 아이템 클릭 시 전체 본문 내용과 원문 링크를 확인할 수 있는 전용 뷰어 제공
- **상태 동기화:** 모드 열람 시 해당 아이템의 읽음 상태가 시스템에 자동으로 반영 및 표시



중요 정보 분류 및 조회 최적화

- **중요도 관리:** 별표(Star) 기능을 활용하여 핵심 보안 위협 정보를 별도로 마킹하고 관리
- **목록 최적화:** 페이지네이션(10~100개 단위) 및 페이지 직접 이동을 통해 대규모 피드 데이터 조회 효율화





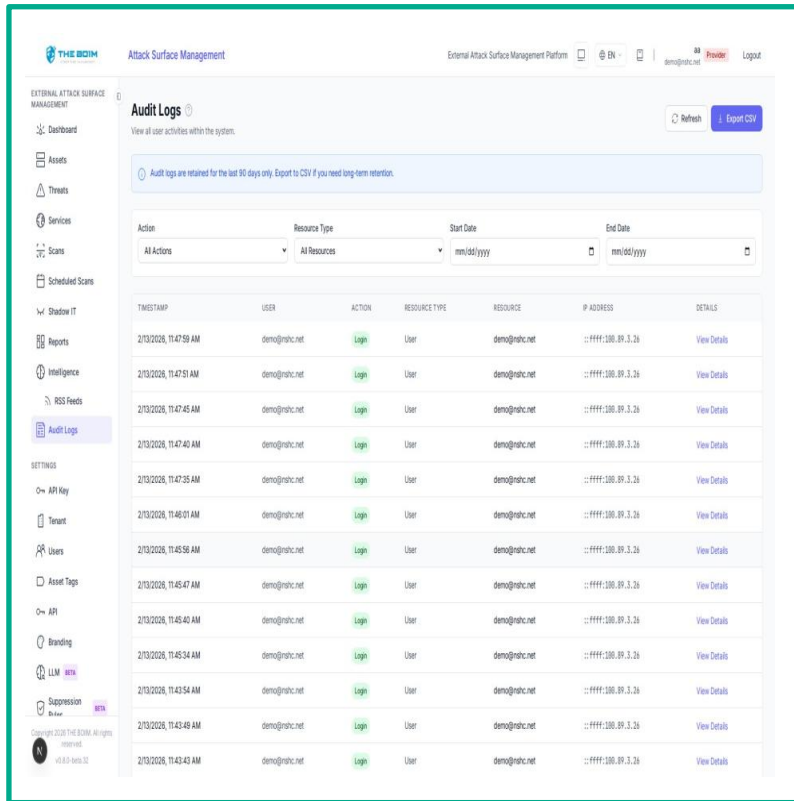
09

10. 감사 로그

활동 기록, 필터링

11

10. 감사 로그 - 감사 로그 조회



The screenshot shows the 'Audit Logs' section of the THE BCIM External Attack Surface Management Platform. The interface includes a sidebar with navigation options like Dashboard, Assets, Threats, Services, Scans, Scheduled Scans, Shadow IT, Reports, Intelligence, RSS Feeds, and Audit Logs (selected). The main content area displays a table of audit logs with columns for Timestamp, User, Action, Resource Type, Resource, IP Address, and Details. The table shows a series of 'Login' actions performed by 'demo@nshc.net' on 'demo@nshc.net' resources. Above the table, there are filters for Action (All Actions), Resource Type (All Resources), and date ranges. A note indicates that audit logs are retained for the last 90 days only and can be exported to CSV.

TIMESTAMP	USER	ACTION	RESOURCE TYPE	RESOURCE	IP ADDRESS	DETAILS
21/3/2026, 11:47:59 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:47:51 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:47:45 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:47:40 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:47:35 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:48:01 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:45:58 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:45:47 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:45:40 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:45:34 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:43:54 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:43:49 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details
21/3/2026, 11:43:43 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:198b:bf:3:3a	View Details

플랫폼 내 모든 주요 활동의 자동 기록을 통한 보안 가시성 및 책임 추적성 확보

8개 핵심 모듈별 주요 액션 자동 기록



- 추적 범위: auth, asset, threat, scan, intelligence, suppression, report, settings 등 8개 모듈 대상
- 기록 항목: 로그인, 자산 변경, 스캔 실행, 위협 상태 변경, 설정 변경 등 사용자 및 시스템의 주요 액션 자동 저장

로그 데이터 구성 및 상세 조회 기능



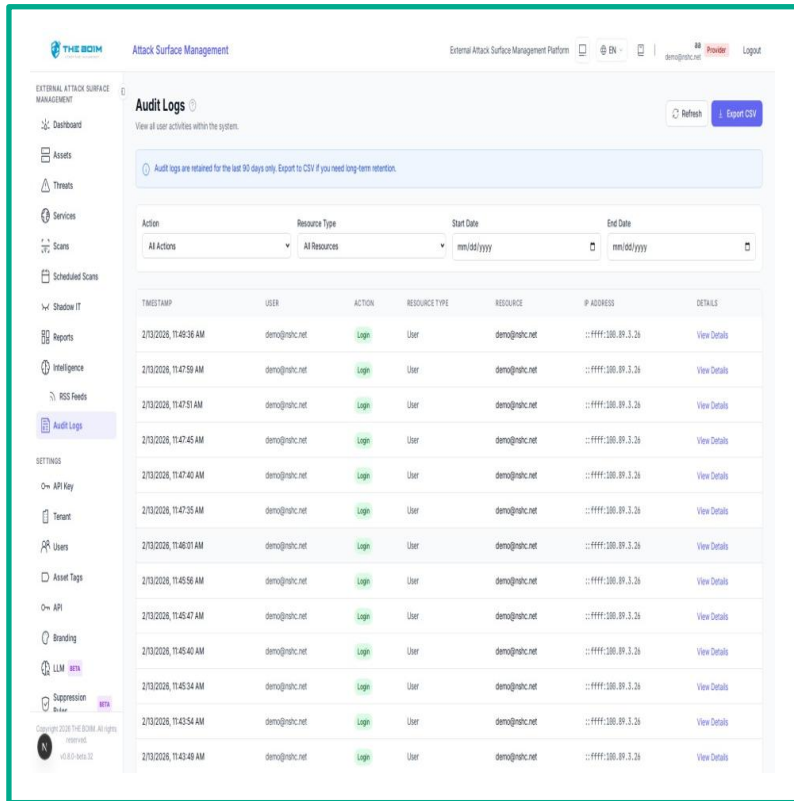
- 데이터 항목: 발생 시간(Timestamp), 사용자 정보, 액션 유형, 자산 유형, 리소스명, 접속 IP 주소 등 제공
- 상세 분석: 각 로그 항목의 'View Details' 링크를 통해 액션과 관련된 세부 데이터 및 변경 전후 내용 확인 가능

로그 보존 정책 및 감사 증거 활용



- 보존 정책: 기본 90일간 데이터를 보존하며, 환경변수 설정을 통해 조직별 요구사항에 맞춰 보존 기간 조정 가능
- 증적 확보: CSV 내보내기 기능을 통해 대량의 로그 데이터를 추출하여 컴플라이언스 감사 및 보안 사고 분석 증적으로 활용

10. 감사 로그 - 필터링 및 검색



Audit Logs

View all user activities within the system.

Audit logs are retained for the last 90 days only. Export to CSV if you need long-term retention.

Refresh Export CSV

Action: All Actions Resource Type: All Resources Start Date: mm/dd/yyyy End Date: mm/dd/yyyy

TIMESTAMP	USER	ACTION	RESOURCE TYPE	RESOURCE	IP ADDRESS	DETAILS
2/13/2026, 11:45:36 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:47:59 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:47:51 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:47:45 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:47:40 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:47:35 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:46:01 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:45:56 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:45:47 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:45:40 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:45:34 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:45:54 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details
2/13/2026, 11:43:49 AM	demo@nshc.net	Login	User	demo@nshc.net	::ffff:100.89.3.26	View Details

다각적 필터링과 검색 기능을 통한 대용량 감사 로그의 신속한 식별 및 조회

4개 조건 기반의 감사 로그 정밀 필터링

- **필터 기준:** 기간(날짜 범위), 사용자(Email), 모듈(Resource Type), 액션 타입별 필터링 지원
- **신속 조회:** 검색 기능을 병행하여 특정 사용자 이름, IP 주소, 리소스명을 실시간으로 식별 가능

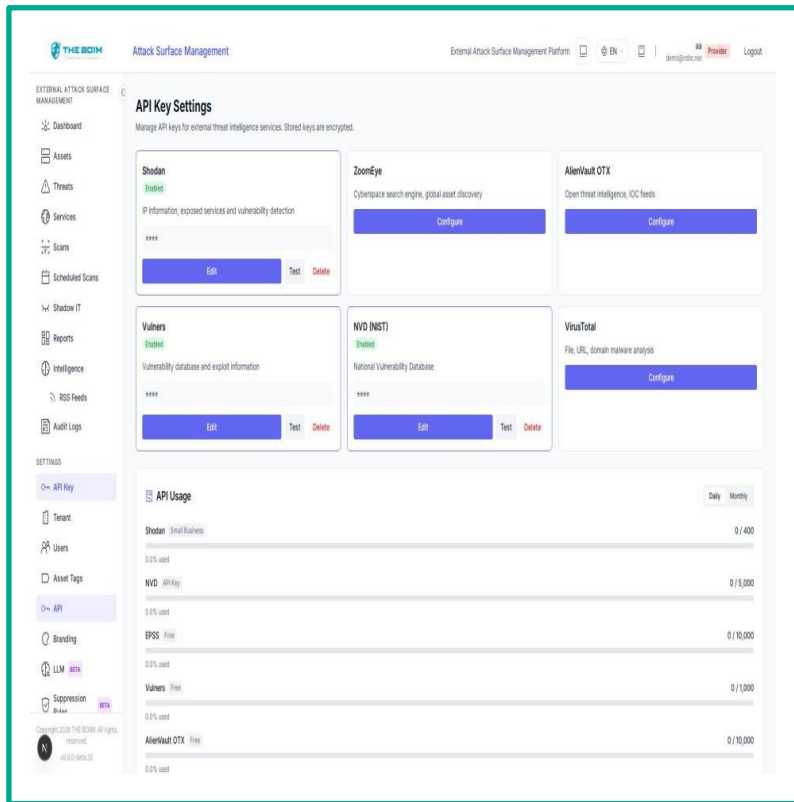
로그 상세 정보 구성 및 데이터 가독성 확보

- **항목:** 사용자명, IP 주소, User-Agent, 액션 타입, 상세 내용, 타임스탬프 정보 포함
- **조회 최적화:** 페이지네이션(10~100개 단위) 및 페이지 직접 이동을 통해 대량 로그 데이터 조회 효율화

사용자 행위 분석을 위한 증적 상세 데이터

- **상세 뷰어:** 각 로그의 'View Details'를 통해 발생한 이벤트의 원문 데이터와 구체적인 행위 내용 확인
- **사후 분석:** 타임스탬프와 User-Agent 정보를 결합하여 보안 사고 발생 시 원인 분석을 위한 증적으로 활용

10. 감사 로그 - API 키 관리



외부 보안 서비스와의 안전한 연동 및 API 사용량 실시간 모니터링

다양한 외부 위협 인텔리전스 서비스 연동 지원

- **지원 서비스:** NVD, Shodan, Censys, VirusTotal, AlienVault OTX 등 주요 보안 서비스 API 연동
- **연동 관리:** 각 서비스별 API 키 등록, 수정, 삭제 기능 및 실제 연동 여부를 확인하는 'Test' 기능 제공

AES-256 암호화 기반의 안전한 키 저장 체계

- **보안 저장:** 등록된 모든 API 키는 AES-256 알고리즘으로 암호화되어 데이터베이스에 안전하게 저장
- **정보 보호:** 관리 화면상에서는 보안을 위해 모든 API 키가 마스킹 처리되어 노출 방지

서비스별 API 사용량 통계 대시보드 제공

- **현황 추적:** 당일 사용량, 최근 7일/30일, 현재 월 단위의 서비스별 API 호출 통계 확인
- **쿼터 관리:** 서비스별 무료/유료 쿼터 제한량 대비 현재 사용량을 시각화하여 안정적인 서비스 연동 유지



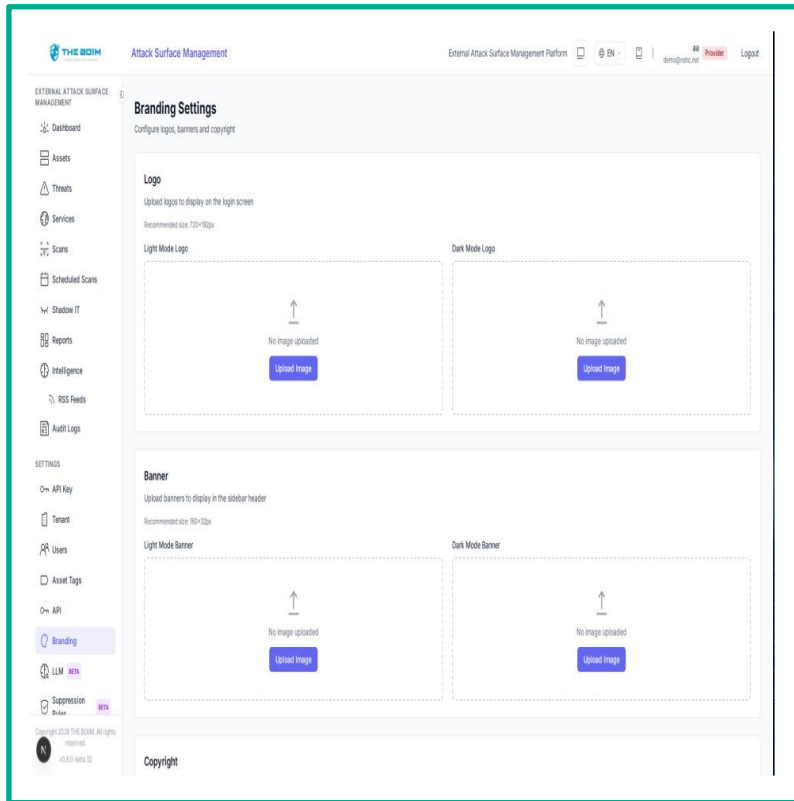
10

11. 설정

API 키, 브랜딩, LLM, 사용자

12

● 11. 설정 브랜딩



로고, 배너, 카피라이트 커스터마이징을 통한 맞춤형 UI/UX 환경 구축

로고 및 배너의 맞춤형 시각화 설정



- **로고 커스터마이징:** 헤더 및 로그인 페이지에 표시될 조직 전용 로고 등록 기능 제공
- **배너 커스터마이징:** 대시보드 상단 및 사이드바 영역에 노출될 브랜딩 배너 이미지 설정

테마별 이미지 등록 및 지원 포맷



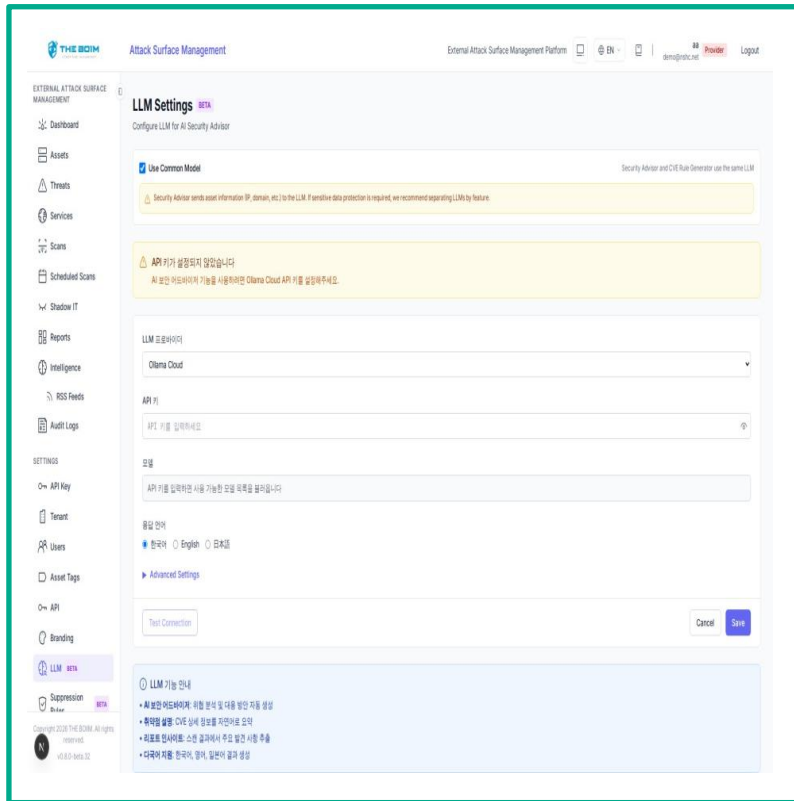
- **모드별 대응:** 라이트 모드(Light Mode)와 다크 모드(Dark Mode) 환경에 최적화된 개별 이미지 등록 지원
- **지원 포맷:** 웹 환경에서 범용적으로 사용되는 PNG, JPG, SVG 형식의 이미지 파일 업로드 가능

조직 법적 정보 및 카피라이트 관리



- **푸터 관리:** 플랫폼 최하단 푸터 영역에 표시될 카피라이트 텍스트 직접 입력 및 수정 가능
- **아이덴티티 강화:** 조직 명칭 및 법적 공고 사항을 명시하여 브랜드 일관성 및 신뢰도 확보

11. 설정 - LLM 설정



멀티 LLM 프로바이더 지원 및 매개변수 최적화를 통한 AI 분석 엔진 구축

5개 주요 LLM 프로바이더 선택 및 연결 관리



- **지원 모델:** OpenAI, Anthropic, Gemini, Ollama Cloud, Ollama 로컬 중 최적의 AI 엔진 선택 가능
- **유연한 구성:** 보안 어드바이저와 CVE 룰 생성기별로 별도 모델을 설정하거나 공통 모델 사용 가능

AI 응답 품질 정밀 제어를 위한 고급 매개변수 설정



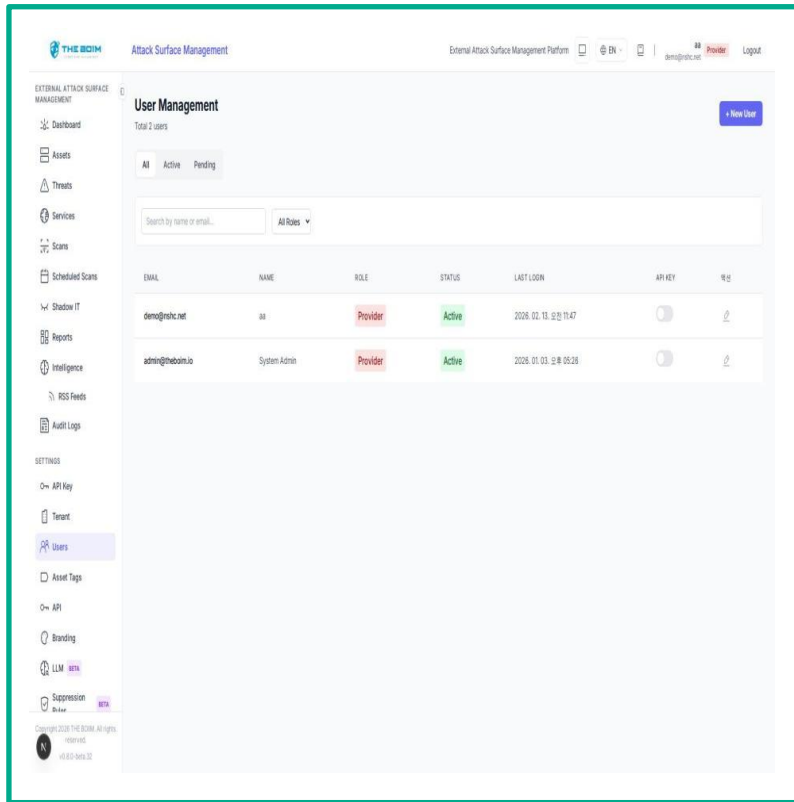
- **품질 최적화:** 최대 토큰 수(Max Tokens), Temperature, Top P, Frequency Penalty 등 상세 파라미터 조정
- **언어 및 검색:** 한국어/영어/일본어 등 다국어 응답 지원 및 최신 정보 반영을 위한 웹 검색 활성화 옵션 제공

주요 AI 기반 보안 기능 및 성능 검증



- **핵심 기능:** 취약점 위험 분석 및 대응 방안 자동 생성, 복잡한 CVE 상세 정보 요약, 다국어 결과 생성
- **안정성 확보:** 설정된 API 키와 엔드포인트에 대한 '연결 테스트' 기능을 통해 실시간 작동 상태 검증

11. 설정 - 사용자 관리



5단계 역할 기반 권한 제어(RBAC)를 통한 테넌트 보안 및 협업 환경 최적화

5단계 역할 체계 기반의 차등 권한 부여



- **역할 분류:** Owner, Admin, Editor, Analyst, Viewer 순의 5개 레벨로 권한 세분화
- **접근 제어:** 각 역할에 따라 시스템 설정 변경, 자산 수정, 데이터 조회 등 수행 가능 범위를 엄격히 차등화

사용자 초대 및 단계별 승인 프로세스



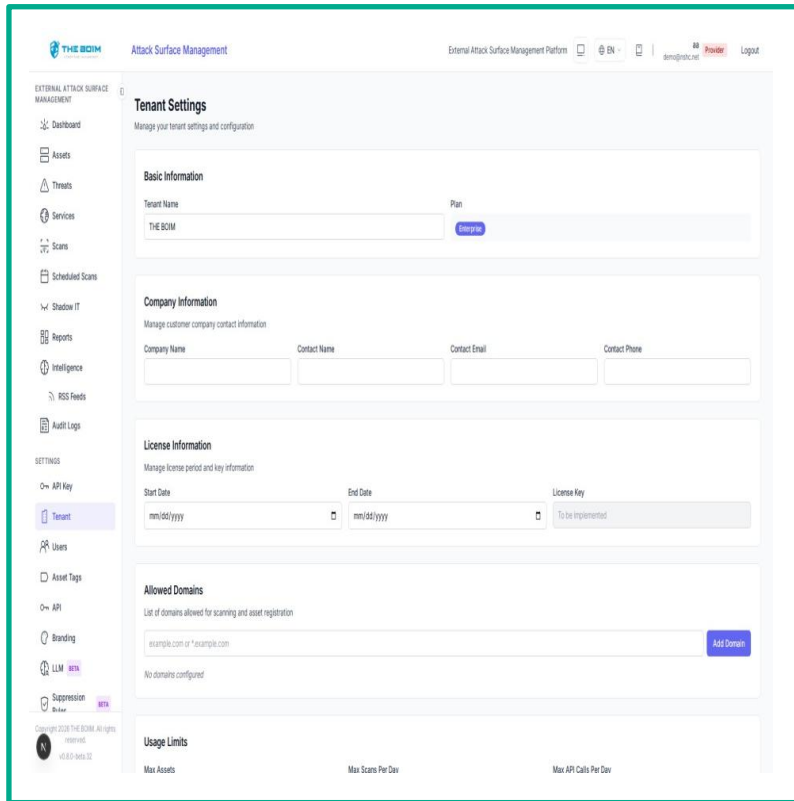
- **초대 절차:** 이메일, 이름, 역할, 임시 비밀번호 입력을 통해 신규 사용자 초대 실행
- **로그인 승인:** 초대된 사용자는 '미승인' 상태로 생성되며, Owner 또는 Admin의 최종 승인 후 플랫폼 접속 가능

계정 활성화 상태 관리 및 API 키 제어



- **상태 제어:** 비활성화를 통해 임시적인 로그인 차단이 가능하며, 필요 시 계정 영구 삭제 기능 제공
- **기능 토글:** 개별 사용자별로 API 키 사용 권한을 활성화/비활성화할 수 있는 토글 옵션 지원

11. 설정 - 테넌트 설정



Tenant Settings
Manage your tenant settings and configuration

Basic Information

Tenant Name: THE B2M Plan: Choose Plan

Company Information
Manage customer company contact information

Company Name: Contact Name: Contact Email: Contact Phone:

License Information
Manage license period and key information

Start Date: mm/dd/yyyy End Date: mm/dd/yyyy License Key: To be implemented

Allowed Domains
List of domains allowed for scanning and asset registration

example.com or *example.com Add Domain

No domains configured

Usage Limits

Max Assets: Max Scans Per Day: Max API Calls Per Day:

조직별 맞춤형 정책 설정 및 리소스 쿼터 제한을 통한 안정적 플랫폼 운영

조직 정보 및 서비스 라이선스 관리



- **기본 정보:** 테넌트 명칭, 회사 정보(담당자명, 연락처, 이메일) 및 현재 구독 플랜 정보 관리
- **라이선스 제어:** 라이선스 키 등록 및 유효 기간(시작일/종료일) 설정을 통한 정식 서비스 상태 유지

허용 도메인 및 리소스 사용량 제한 설정



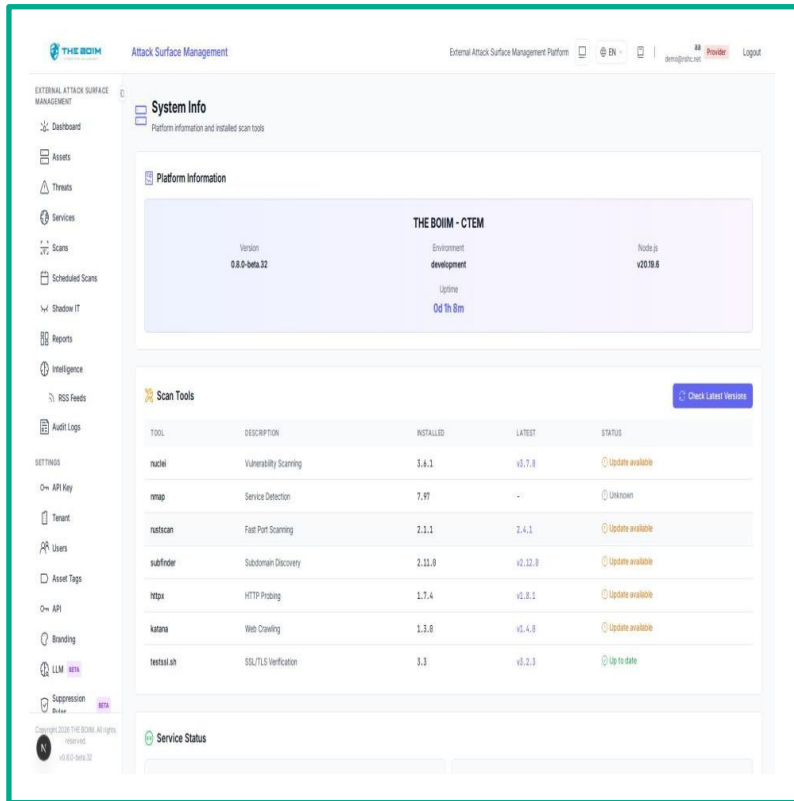
- **자산 통제:** 허용 도메인 등록을 통해 무분별한 자산 검색 방지 및 모니터링 대상 범위 확정
- **쿼터 제한:** 최대 자산 수, 일일 최대 스캔 수, 일일 최대 API 호출 수 설정을 통해 인프라 리소스 최적화

Lab 기능 활성화 및 AI 모델 사용량 제어



- **기능 토글:** 보안 어드바이저, CVE 롤 생성기 등 신규 Lab 기능의 전체 및 개별 활성화 제어
- **AI 쿼터 관리:** AI 분석 기능의 월간 사용량을 제한하고 초기화 시점을 설정하여 운영 비용 관리

11. 설정 - 시스템 정보



The screenshot shows the 'System Info' page of the 'EXTERNAL ATTACK SURFACE MANAGEMENT' interface. The page is titled 'System Info' and 'Platform information and installed scan tools'. It features a 'Platform Information' section with details for 'THE BOIM - CTEM', including Version (0.8.0-beta.32), Environment (development), Node.js (v20.10.0), and Uptime (0d 1h 5m). Below this is a 'Scan Tools' table listing various tools and their status.

TOOL	DESCRIPTION	INSTALLED	LATEST	STATUS
nuclei	Vulnerability Scanning	3.4.1	v3.7.0	Update available
nmap	Service Detection	7.97	-	Unknown
rustscan	Fast Port Scanning	2.1.1	2.4.1	Update available
subfinder	Subdomain Discovery	2.11.0	v3.12.0	Update available
httpx	HTTP Probing	1.7.4	v2.0.1	Update available
katana	Web Crawling	1.3.0	v2.4.0	Update available
testssl.sh	SSL/TLS Verification	3.3	v3.2.3	Up to date

플랫폼 버전 관리 및 주요 스캔 도구의 최신성·연결 상태 실시간 점검

플랫폼 구동 환경 및 기술 사양 확인

- 시스템 기본 정보: 플랫폼 이름, 현재 버전(0.8.0-beta.32), Node.js 버전, 시스템 가동 시간(Uptime) 표시
- 환경 식별: 현재 구동 중인 개발(Development) 또는 운영 환경 정보 가시화

8개 핵심 스캔 도구의 버전 및 업데이트 관리

- 버전 조회: Nuclei, Nmap, Rustscan, Subfinder, Httpx, Katana, TestSSL, Amass 등 8개 엔진 버전 표시
- 최신성 검증: GitHub 릴리스 기준 최신 버전 자동 조회 및 업데이트 필요 여부(Update available) 실시간 식별

주요 백엔드 서비스 연결 상태 모니터링

- 서비스 상태: PostgreSQL, Redis, BullMQ 등 시스템 핵심 서비스의 연결 유효성 표시
- 안정성 확보: 인프라 서비스별 실시간 상태를 시각화하여 플랫폼 운영의 안정성 및 가용성 확보



11

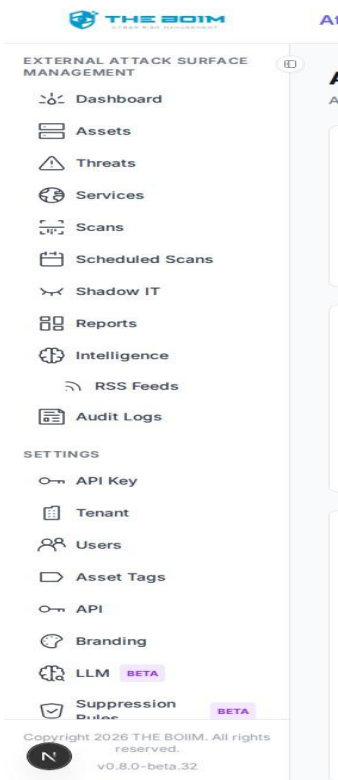
12. 실험실

Tor, 엔드포인트, CVE 룰, AI

13

12. 실험실 - LAB(실험실) 개요

혁신적 기능의 선제적 체험 및 피드백 수집을 위한 실험적 플레이그라운드



Lab 모듈의 목적 및 기능적 가치



- **미래 기능 체험:** 정식 출시 전 개발 중인 실험적이고 혁신적인 보안 기능을 미리 체험할 수 있는 공간 제공
- **사용자 피드백:** 실제 운영 환경에서의 피드백을 수집하여 기능의 완성도를 높이고 정식 기능 전환 여부 결정

테넌트 기반의 기능 활성화 제어 정책



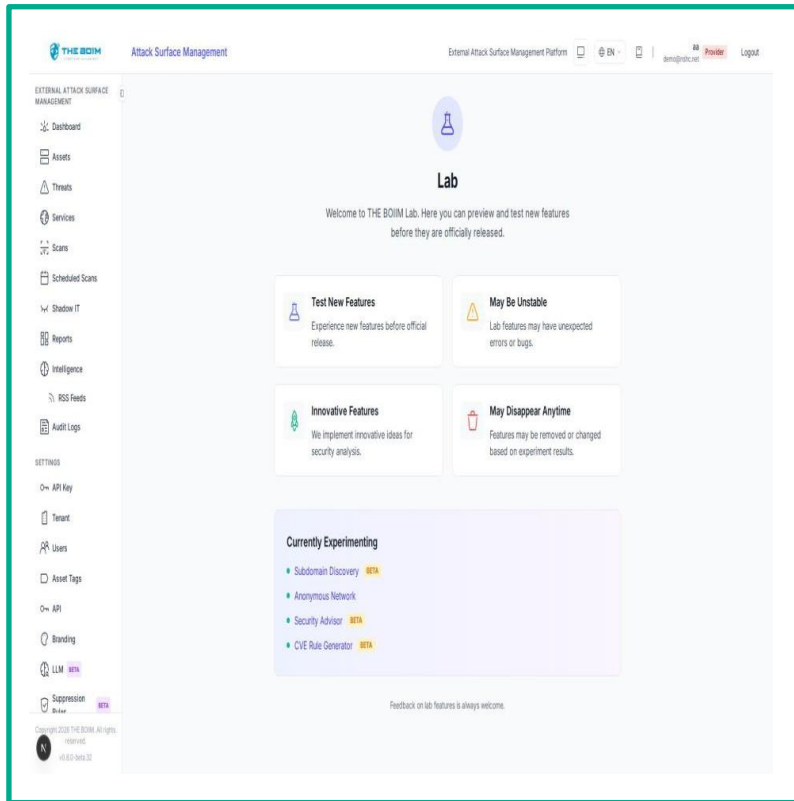
- **개별 활성화:** 테넌트 설정 메뉴를 통해 Lab 전체 기능 또는 특정 하위 기능별로 활성화 여부 선택 가능
- **단계적 배포:** 실험 단계에서 안정성이 확인된 기능에 한해 순차적으로 정식 모듈로 전환 및 통합

운영상의 임시성 및 안정성 주의사항



- **변경 및 제거:** Lab 기능은 성능 개선이나 정책에 따라 언제든지 예고 없이 변경되거나 제거될 수 있음
- **신중한 사용:** 실험적 특성에 따른 불안정성이 존재하므로, 프로덕션(운영) 환경 적용 시 세심한 주의 필요

● 12. 실험실 Playground



현재 제공 중인 실험적 기능 목록 확인 및 통합 관리 인터페이스 제공

Lab 기능 소개 및 상태 가시화



- **메인 페이지:** Lab 모듈 선택 시 나타나는 안내 페이지로, 현재 활성화된 실험 기능들의 목록과 상태를 한눈에 표시
- **바로가기:** 각 기능 카드를 클릭하여 해당 Lab 기능(Tor 모니터링, CVE 룰 생성기 등)으로 즉시 이동 가능

현재 실험 중인 핵심 기능 라인업



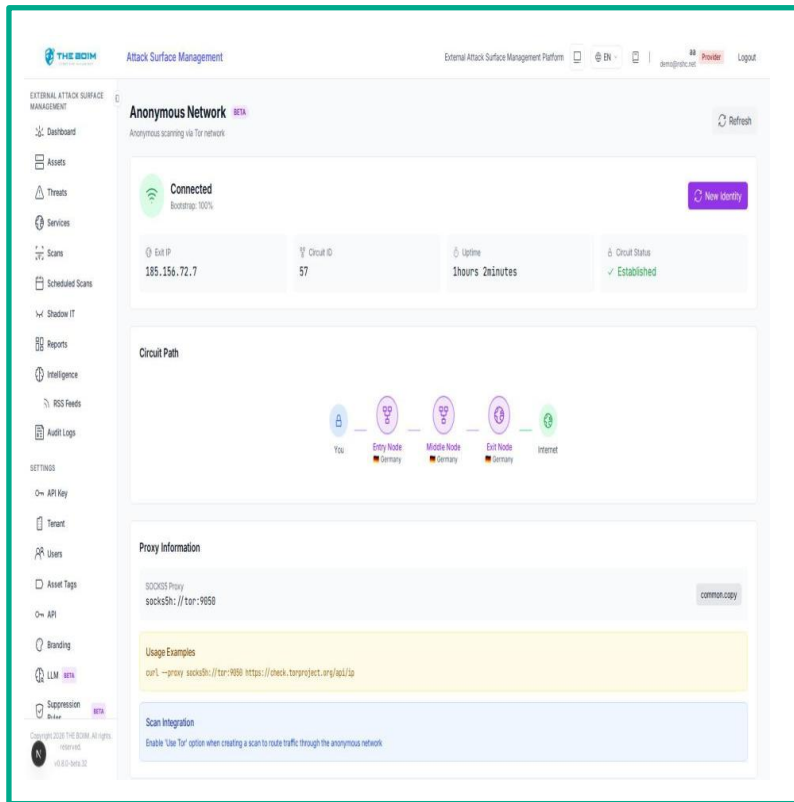
- **주요 기능:** Subdomain Discovery, Anonymous Network(Tor), Security Advisor, CVE Rule Generator 등 포함
- **활성화 표시:** 각 기능 옆에 'BETA' 태그를 부착하여 정식 기능과 차별화된 실험 단계임을 명시

데이터 보존 및 보안 책임 정책 안내



- **주의사항:** 실험적 기능 사용 시 데이터 보존 정책, 보안 책임, 성능 및 안정성 측면의 유의사항을 사전에 안내
- **운영 안내:** 기능의 불안정성(Unstable) 및 예고 없는 제거(May Disappear) 가능성에 대한 사용자 인지 강화

12. 실험실 - Tor 익명 네트워크 모니터링



실시간 회로 시각화 및 Tor 프록시 연동을 통한 익명 스캔 환경 구축

Tor 네트워크 연결 상태 및 성능 모니터링

- **연결 정보:** 연결 상태(Connected), Bootstrap 진행률, 현재 할당된 Exit IP 주소 정보 실시간 제공
- **성능 지표:** 현재 할당된 Circuit ID 및 네트워크 가동 시간(Uptime), 가동 상태(Established) 표시



익명성 강화를 위한 실시간 회로(Circuit) 시각화

- **경로 분석:** Entry Node, Middle Node, Exit Node로 이어지는 세 단계 노드 경로와 각 국가 정보를 시각적 맵으로 제공
- **ID 갱신:** 'New Identity' 기능을 활용하여 필요 시 즉시 새로운 회로를 구성하고 Exit IP를 변경하여 익명성 강화

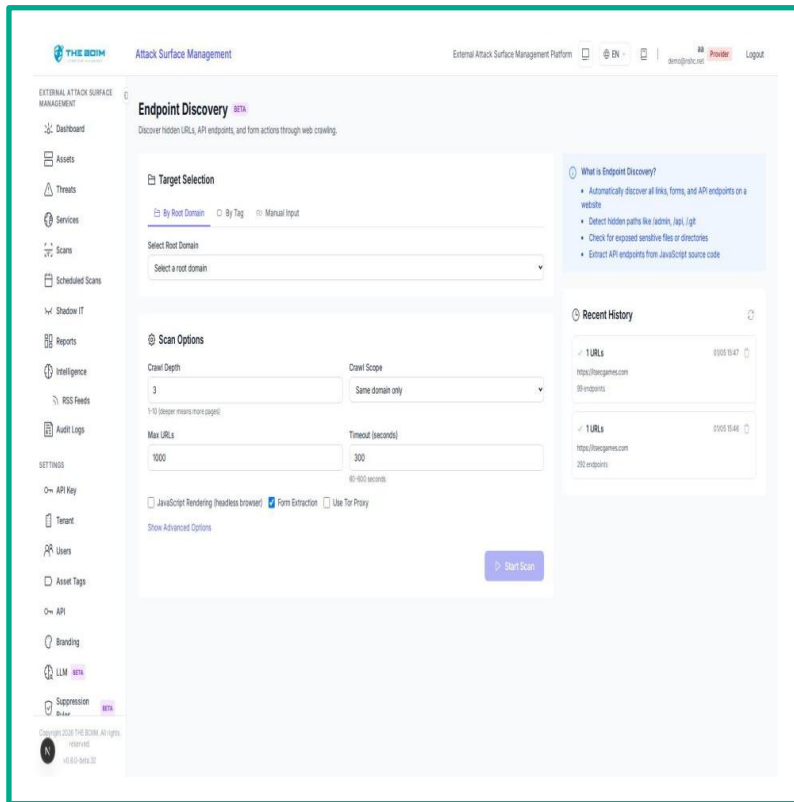


서비스 스캔 도구와의 프록시 연동 및 제약 사항

- **스캔 연동:** Vulnerability, Endpoint, Header, Subdomain 스캔 시 Tor 프록시(SOCKS5)를 사용하도록 설정 가능
- **제약 사항:** HTTP/HTTPS 기반 스캔에 최적화되어 있으며, Port 스캔 및 SSL 상세 검증 시에는 사용이 제한됨



12. 실험실 - 엔드포인트 디스커버리



심층 웹 크롤링을 통한 숨겨진 URL 및 API 엔드포인트의 자동 식별



Katana 크롤러 기반의 웹 애플리케이션 심층 탐색

- **탐색 범위:** 웹 페이지 내 숨겨진 링크, 폼 액션, API 엔드포인트, 관리자 페이지 등을 자동으로 탐색 및 식별
- **민감 정보 식별:** 설정 파일, 백업 파일, 노출된 소스코드 내 정적 리소스 등 보안 취약점이 될 수 있는 엔드포인트 탐지



정밀 탐색을 위한 스캔 옵션 커스터마이징

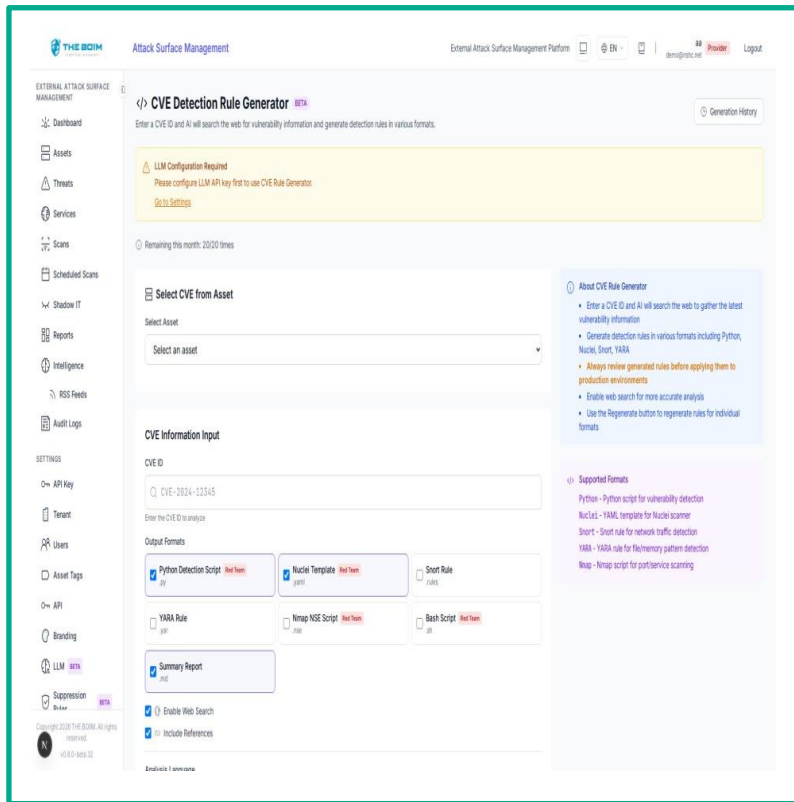
- **상세 설정:** 탐색 깊이(Crawl Depth), 탐색 범위(Scope), 최대 URL 수, 타임아웃 등 환경별 최적화 옵션 제공
- **고급 기술:** JavaScript 렌더링(Headless browser) 지원을 통해 동적 페이지 분석 및 Tor 프록시 연동 스캔 가능



탐색 결과 분석 및 데이터 내보내기

- **자동 하이라이트:** 탐색된 결과 중 보안상 위험할 수 있는 민감한 엔드포인트를 시스템이 자동으로 분류하여 강조
- **데이터 활용:** 탐색 완료 후 전체 엔드포인트 목록을 CSV 또는 JSON 형식으로 추출하여 외부 분석 도구와 연계 지원

12. 실험실 - CVE 룰 생성기



AI 기반 다중 포맷 탐지 스크립트 생성을 통한 신속한 취약점 대응 체계 구축



LLM 연동을 통한 지능형 CVE 분석 및 룰 생성

- 자동 분석: CVE 번호 입력 시 NVD API에서 정보를 실시간 조회하고, LLM이 취약점 특성에 맞는 탐지 로직 분석
- 맞춤 스크립트: 분석된 데이터를 바탕으로 실제 보안 도구에서 즉시 사용 가능한 맞춤형 탐지 스크립트 자동 생성



7가지 보안 도구별 출력 형식 및 유효성 검증

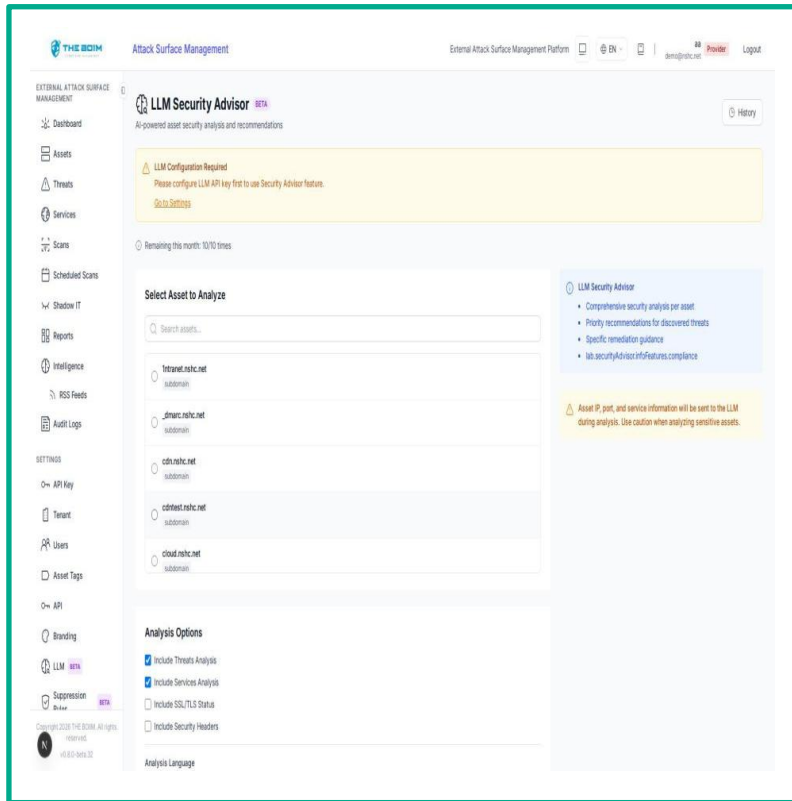
- 지원 포맷: Python, Nuclei, YARA, Snort, Suricata, Nmap NSE, Bash 등 7가지 주요 형식 지원
- 품질 제어: 내장된 구문 검증기(Syntax Checker)를 통해 생성된 코드의 유효성을 확인하고 최적화된 프롬프트 적용



분석 정확도 향상을 위한 검색 및 참조 옵션

- 웹 검색 연동: 최신 취약점 동향 및 PoC(Proof of Concept) 코드를 반영하기 위한 실시간 웹 검색 기능 지원
- 결과 요약: 생성된 룰에 대한 상세 설명 및 조치 권고 사항을 포함한 Summary Report 함께 제공

12. 실험실 - Security Advisor



AI 기반 자산 보안 상태 분석 및 자연어 기반의 맞춤형 조치 권고 제공



LLM 기반의 자산별 위협 현황 정밀 분석

- **분석 메커니즘:** 자산 상세 페이지에서 'AI 분석' 버튼 클릭 시, 탐지된 위협 및 취약점 데이터를 LLM 엔진이 정밀 분석
- **가시성 확보:** 복잡한 보안 데이터를 분석하여 위협 현황과 우선순위를 관리자가 이해하기 쉬운 자연어로 제시



사용자 맞춤형 보안 조치 권고 및 가이드 제공

- **맞춤형 권고:** 식별된 취약점의 기술적 특성을 고려하여 해당 자산에 최적화된 구체적인 조치 방안 생성
- **의사결정 지원:** 위협의 위험도와 비즈니스 영향을 평가하여 보안 담당자의 신속한 대응 의사결정을 지원



유연한 LLM 프로바이더 선택 및 연동 설정

- **엔진 선택:** 조직의 보안 정책에 따라 OpenAI, Anthropic, Gemini 등 클라우드 LLM 또는 Ollama 기반 로컬 LLM 선택 가능
- **통합 설정:** 'Settings > LLM' 메뉴에서 API 키 및 프로바이더를 일괄 관리하여 보안 분석 기능의 안정적 운영 보장

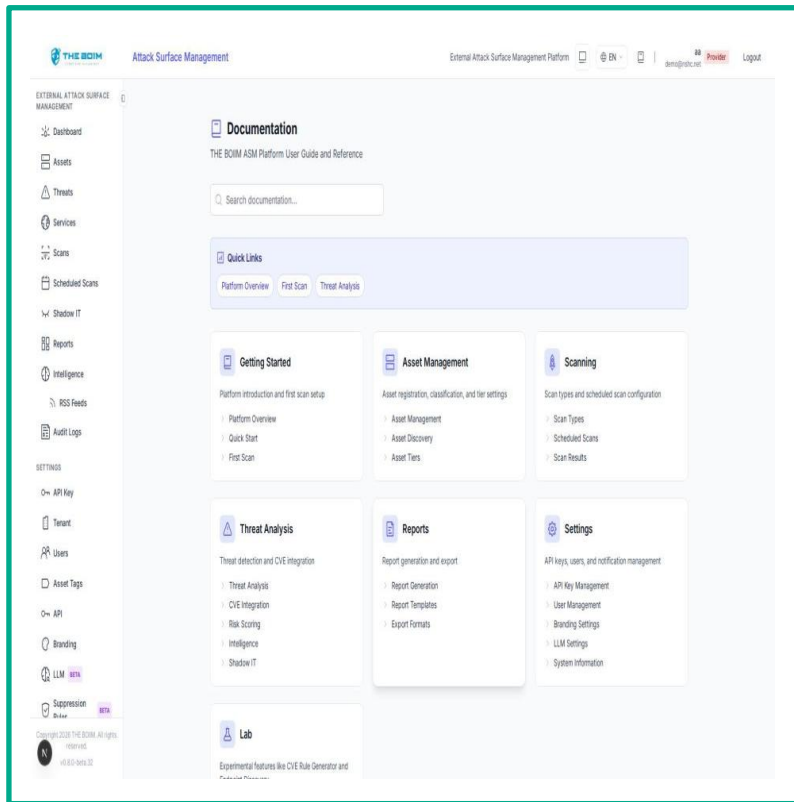


12

13. 웹 메뉴얼

웹 메뉴얼

13. 웹 매뉴얼



기능별 상세 가이드 및 다국어 지원을 통한 사용자 운영 편의성 극대화

플랫폼 통합 웹 매뉴얼 제공 및 접근성



- **상시 지원:** 플랫폼 내 'Documentation' 메뉴를 통해 별도의 문서 파일 없이 언제든지 실시간 사용법 확인 가능
- **접근 경로:** /easm/docs 경로를 통해 직접 접근이 가능하며, 최신 시스템 버전 정보와 동기화된 가이드 제공

3개 국어 지원 및 기능별 전문 가이드 구성



- **다국어 대응:** 글로벌 운영 환경을 고려하여 한국어, 영어, 일본어의 3개 국어 매뉴얼 공식 지원
- **단계별 구성:** 자산 관리(Asset), 스캔(Scanning), 위협 분석(Threat Analysis), 보고서(Reports) 등 핵심 모듈별 상세 섹션 제공

지능형 검색 및 퀵 링크(Quick Links) 활용



- **신속 검색:** 통합 검색 기능을 통해 사용자가 원하는 기능 설명이나 보안 용어 설명을 빠르게 식별
- **사용자 온보딩:** 'Platform Overview', 'First Scan' 등 퀵 링크를 제공하여 신규 관리자의 초기 설정 및 적응 지원

Thank you
감사합니다.